



Máster en Ciberinteligencia

5ª Edición

Trabajo Fin de Master

**CIBERAMENAZAS EN EL SECTOR
TRANSPORTE Y LOGÍSTICO ESPAÑOL**

**ANÁLISIS DE ACTORES E IMPLEMENTACIÓN DE UN
SISTEMA DE DETECCIÓN Y EXTRACCIÓN DE IOCS
AUTOMATIZADO**

AUTORES: Miguel Ángel Maldonado Vela

Miguel Alvariño Blanes

Víctor Bravo García

TUTOR: Iván Portillo Morales

Resumen

La transformación digital y la adopción de modelos operativos *Just-In-Time* han convertido al sector logístico y de la cadena de suministro en una infraestructura crítica altamente vulnerable a los ciberataques.

El presente Trabajo de Fin de Máster (TFM) propone el diseño, desarrollo e implementación de una arquitectura automatizada de Inteligencia de Ciberamenazas (CTI) orientada a la protección proactiva de este sector. Este trabajo, entre otros objetivos, aborda uno de los mayores desafíos de los Centros de Operaciones de Seguridad (SOC) modernos: la "Fatiga de Alertas" (Alert Fatigue), resultado del ruido y los falsos positivos originado en la ingesta de datos. Para resolverlo, se ha desarrollado un conjunto de scripts (*scrapers*) en Python que recopilan telemetría de fuentes heterogéneas (Dark Web, Shodan, AlienVault OTX, Pastebin y Feeds OSINT).

No solamente se recopilan datos de forma automatizada si no que se implementa un modelo de filtrado refinado mediante Expresiones Regulares (Regex). Adicionalmente, de forma más estratégica que operativa, se integra un perfilado estratégico de actores de amenazas mapeados bajo el framework MITRE ATT&CK. Toda esta inteligencia validada se inyecta de forma automatizada en la plataforma de inteligencia MISP que, a su vez, se ingesta a un SIEM (Wazuh) y este, dependiendo del nivel de alerta definido, envía alertas formateadas a un bot en la plataforma de mensajería Telegram.

Otro de los hitos es la implementación de un agente IA para la búsqueda y extracción automatizada de los IOC's contenidos en los diferentes formatos de documentos ingestados previamente. Dicho agente, transforma dichos IOCs en reglas Wazuh para posteriormente inyectarlas en el SIEM.

Durante todo el proceso, un analista ha recopilado información mediante técnicas OSINT utilizando diferentes metodologías, aportando su capacidades analíticas y cognitivas, la cuales siguen siendo críticas y necesarias a la hora de buscar, contextualizar, filtrar, evaluar y analizar la información en un mundo cada vez más transformado de forma inevitable por la IA.

Con este trabajo, pasaríamos del clásico modelo reactivo a una visión más proactiva y predictiva, la cual puede reducir drásticamente la materialización de una amenaza en el sector empresarial, concretamente en el sector logístico.

Palabras clave: *Ciberseguridad, Logística, Inteligencia de Ciberamenazas (CTI), MISP, SIEM, Fatiga de Alertas, OSINT, Scrapers, Agente IA, Analista, Automatización.*

Abstract

Digital transformation and the adoption of Just-In-Time operating models have turned the logistics and supply chain sector into a critical infrastructure that is highly vulnerable to cyberattacks. This Master's Thesis (TFM) proposes the design, development, and implementation of an automated Cyber Threat Intelligence (CTI) architecture oriented toward the proactive protection of this sector. Among other objectives, this work addresses one of the greatest challenges faced by modern Security Operations Centers (SOCs): "Alert Fatigue," which results from the noise and false positives generated during data ingestion. To resolve this, a set of Python-based scrapers was developed to collect telemetry from heterogeneous sources (Dark Web, Shodan, AlienVault OTX, Pastebin, and OSINT feeds).

Data is not only collected automatically, but a refined filtering model using Regular Expressions (Regex) is also implemented. Additionally, on a more strategic than operational level, the architecture integrates threat actor profiling mapped under the MITRE ATT&CK framework. All this validated intelligence is automatically injected into the MISP threat intelligence platform, which in turn feeds into a SIEM (Wazuh). Depending on the defined alert level, the SIEM sends formatted alerts to a bot on the Telegram messaging platform.

Another milestone is the implementation of an AI agent for the automated search and extraction of IOCs contained in various document formats. This agent transforms these IOCs into Wazuh rules to subsequently inject them into the SIEM. Throughout the entire process, an analyst gathered information using OSINT techniques across different methodologies, contributing analytical and cognitive capabilities. These skills remain critical and necessary when searching, contextualizing, filtering, evaluating, and analyzing information in a world inevitably transformed by AI.

With this work, the approach shifts from the classic reactive model to a more proactive and predictive vision, which can drastically reduce the materialization of threats in the business sector, specifically within logistics.

Keywords: *Cybersecurity, Logistics, Cyber Threat Intelligence (CTI), MISP, SIEM, Alert Fatigue, OSINT, Scrapers, AI Agent, Analyst, Automation.*

Índice

RESUMEN.....	2
ABSTRACT.....	3
ÍNDICE.....	4
ÍNDICE DE TABLAS.....	6
ÍNDICE DE FIGURAS.....	6
1. INTRODUCCIÓN.....	8
1.1 Contexto y motivación: La criticidad del sector transporte y la convergencia IT/OT	8
1.2 Planteamiento del problema: La dispersión de amenazas en tierra, mar y aire	10
1.3 Objetivos	11
1.3.1 Objetivo general.....	11
1.3.2 Objetivos específicos	11
1.4 Alcance.....	12
1.5 Estructura del documento.....	12
2. ESTADO DEL ARTE Y MARCO TEÓRICO	14
2.1 Ciberamenazas en el Sector Transporte	14
2.1.1 Vertical Tierra: Logística, flotas y sistemas ferroviarios	14
2.1.2 Vertical Mar: Sistemas de navegación y puertos inteligentes	15
2.1.3 Vertical Aire: Control aéreo y sistemas aeroportuarios	16
2.2 Taxonomía de Actores de Amenaza (Threat Actors)	17
2.2.1 Actores Estatales (APT) y ciberespionaje industrial	18
2.2.2 Ransomware-as-a-Service (RaaS)	19
2.2.3 Hacktivismo.....	20
2.3 Casos confirmados en el sector transporte español (2025-2026)	21
2.3.1 RaaS	21
2.3.2 Hacktivismo.....	23
2.3.3 Amenaza estatal (APT)	24
2.4 Fundamentos de Ciberinteligencia (CTI).....	24
2.4.1 Ciclo de vida de la inteligencia.....	24
2.4.2 Estándares de intercambio (STIX/TAXII)	25
2.4.3 Frameworks de referencia (MITRE ATT&CK y Pyramid of Pain)	25
3. ANÁLISIS ESTADÍSTICO DE ACTORES VÍA TELEGRAM Y DESARROLLO DE REGLAS WAZUH.....	27
3.1 Caracterización de los actores como método de partida.....	27
3.2 De la inteligencia a la detección: reglas obtenidas	28
3.2.1 Procedimiento de generación y validación.....	28
3.2.2 Archivo Blacknet-00 (BLACKNET-00 y TRK25 SCADA)	28
3.2.3 Archivo ZPENTEST ALLIANCE (ZPENTEST ALLIANCE, RubinGroup/RubinView).....	31
3.2.4 Archivo APK (AvangardSec, pol4rity, KIDS) / UAC-0252.....	33
4. ARQUITECTURA CTI: SCRAPERS + MISP + WAZUH + TELEGRAM	36
4.1 Contexto previo sobre la infraestructura.....	36
4.1.1 Evolución de los SOC y la Inteligencia de Ciberamenazas (CTI).....	36
4.1.2 El desafío de la Fatiga de Alertas	36
4.1.3 Soluciones aportadas.....	36

4.2 Elección de plataformas y justificación	37
4.2.1 Plataforma CTI: MISP frente a OpenCTI	37
4.2.2 Motor Analítico: Wazuh frente al Stack ELK	37
4.2.3 Plataforma de mensajería para alertas - Telegram.....	38
4.3 Fase de Ingesta: scrapers y fuentes de inteligencia	39
4.3.1 Características comunes	39
4.3.2 Listado de scrapers.....	39
4.4 Orquestación y Mantenimiento	44
4.4.1 Tareas programadas (Cronjobs).....	44
4.4.2 Ingesta en Wazuh.....	45
4.4.3 Notificación y Resiliencia	45
5. AGENTE DE GENERACIÓN AUTOMÁTICA DE REGLAS DE DETECCIÓN MEDIANTE INTELIGENCIA ARTIFICIAL.....	46
5.1 Introducción y motivación	46
5.1.1 Objetivos del componente	47
5.2 Arquitectura del sistema.....	47
5.2.1 Componentes principales	48
5.2.2 Infraestructura del laboratorio	48
5.3 Flujo de procesamiento	49
5.3.1 Fase 1 — Análisis integral de la amenaza.....	49
5.3.2 Fase 2 — Generación de reglas Wazuh	49
5.3.3 Artefactos generados.....	50
5.4 Desarrollo iterativo: problemas encontrados y soluciones	50
5.4.1 Obsolescencia del SDK de Gemini.....	51
5.4.2 Restricciones de sintaxis de Wazuh 4.x	51
5.4.3 Errores de escapado entre JSON y XML	51
5.4.4 Respuestas vacías del modelo.....	52
5.4.5 Indisponibilidad temporal del modelo (errores 503 y 429).....	52
5.4.6 Generación de reglas excesivamente genéricas	52
5.4.7 Detección de informes duplicados	53
5.4.8 Truncamiento excesivo de los informes.....	53
5.4.9 Externalización de credenciales.....	54
5.4.10 Nomenclatura incorrecta de grupos de reglas.....	54
5.4.11 Indicadores neutralizados (defanged) en los patrones de detección	55
5.4.12 Alucinación de formatos de registro	55
5.4.13 Validación local previa a la aprobación	56
5.4.14 Optimización del consumo de cuota	56
5.4.15 Nomenclatura de grupos y campos en el ecosistema Sysmon (Windows)	57
5.4.16 Regeneración automática ante fallos críticos del validador	58
5.4.17 Referencias huérfanas en reglas compuestas	58
5.4.18 Mejora progresiva del sistema	59
5.5 Integración con la API REST de Wazuh	60
5.5.1 Configuración del usuario de la API.....	60
5.5.2 Flujo de despliegue automatizado.....	61
5.5.3 Rollback ante fallos de la subida y matices de diagnóstico	61
5.6 Ampliación de la cobertura de monitorización	62
5.7 Validación y resultados.....	63
6. LIMITACIONES IDENTIFICADAS.....	65
7. LÍNEAS DE TRABAJO FUTURO.....	68
8. CONSIDERACIONES ÉTICAS Y LEGALES.....	70
9. CONCLUSIONES.....	71

10. BIBLIOGRAFÍA.....	72
11. OTRAS FUENTES CONSULTADAS.....	77
12. LEGISLACIÓN.....	79
13. ANEXOS.....	80
13.1 Anexo I.....	80
Análisis PESTEL:.....	80
13.2 Anexo II.....	82
13.3 Anexo III.....	83
Análisis estadístico Telegram.....	83
13.4 Anexo IV.....	84
13.5 Anexo V.....	85
13.6 Anexo VI.....	86
Índice de confianza de las fuentes.....	86
13.7 Anexo VII.....	87
Glosario.....	87

Índice de tablas

Tabla 1. Datos obtenidos de EuRepoC (2026).....	23
Tabla 2. Grupo 1 (archivo BlackNet): reglas de detección desplegadas.....	31
Tabla 3. Grupo 2 (archivo ZPENTEST): reglas de detección desplegadas.....	32
Tabla 4. Grupo 3 (archivo APK): reglas de detección desplegadas.....	35
Tabla 5. Componentes principales del agente.....	48

Índice de figuras

Fig. 1. Elaboración propia. Ataques contra el sector transporte español (Ransomware.live, 2026).....	22
Fig. 2. Elaboración propia. Subsectores atacados (Ransomware.live, 2026).....	22
Fig. 3. Telemetr.io Infrastructure Destruction Squad.....	29
Fig. 4. Telemetr.io Infrastructure Destruction Squad.....	29
Fig. 5. Vía Telegram. Infrastructure Destruction Squad.....	29
Fig. 6. Vía Telegram. Infrastructure Destruction Squad.....	30
Fig. 7. Vía Telegram. AvangardSec.....	34
Fig. 8. Dashboard de la plataforma de inteligencia MISP.....	37
Fig. 9. Dashboard del SIEM Wazuh.....	38
Fig. 10. Alerta en Telegram (crt.sh).....	40
Fig. 11. Alerta en Telegram (red TOR).....	40
Fig. 12. Alerta en Telegram (OTX).....	41
Fig. 13. Alerta en Telegram (Shodan).....	41
Fig. 14. Alerta en Telegram (paste).....	42
Fig. 15. Alerta en Telegram (ransomware).....	42
Fig. 16. Alerta en Telegram (osint).....	42
Fig. 17. Mail de respuesta de la plataforma EuRepoC.....	43
Fig. 18. Alerta en Telegram (EuRepoC).....	43
Fig. 19. Alerta en Telegram (CiberBuddy).....	44
Fig. 20. Vía Telegram. sharp333. Ataques al transporte español 29/11/2025.....	82
Fig. 21. Vía Telegram. sharp333. Ataques al transporte español 16/02/2026.....	83

Fig. 22. Vía Telegram. sharp333. Ataques al transporte español 20/02/2026	83
Fig. 23. Vía TGStat. NNM057(16). Relación con Shadow ClawZ 404.....	84
Fig. 24. Vía TGStat. inteid. Relación con RubinGroup	84
Fig. 25. Vía TGStat. Svarog Peruno. Relación entre smeshariki, Svarog Peruno, QuietSec, inteid, Z- Pentest, noname057(16)	85
Fig. 26. Vía TGStat. AvangardSec. Relación entre APK e inteid	85
Fig. 27. Vía TGStat. pol4rity. Relación entre APK con QuietSec.....	86

1. Introducción

1.1 Contexto y motivación: La criticidad del sector transporte y la convergencia IT/OT

El transporte constituye uno de los sistemas principales sobre los que se sostiene cualquier sociedad avanzada. Su función no se centra únicamente en el desplazamiento de personas y mercancías, sino que mantiene la continuidad de las cadenas de suministro globales y sostiene la operatividad de infraestructuras críticas, por ello, la Directiva NIS2 lo clasifica como sector de alta criticidad (Directiva UE 2022/2555, 2022). Esta fuerte conexión explica el por qué una detención de un puerto, aeropuerto o nodo logístico no solo produce un efecto local o sectorial, sino que produce un efecto sistémico en la economía (World Economic Forum, 2025).

En el caso español esta criticidad es especialmente alta debido a que España opera el mayor sistema aeroportuario de Europa bajo un único gestor, Aena, además de disponer de una red de puertos de interés general que dirige el grueso de su comercio exterior, siendo alrededor del 96% del intercambiado con terceros países y el 53% del realizado con la Unión Europea (Puertos del Estado, 2022). Por lo tanto, que el transporte en España tenga esa importancia económica y geoestratégica, hace que sea de gran interés para los actores hostiles (ENISA, 2025). Esta afirmación se respalda con datos del Instituto Nacional de Ciberseguridad (INCIBE), que gestionó en 2025 un total de 122.223 incidentes, suponiendo un incremento interanual del 26% (INCIBE, 2026). De 401 incidentes registrados contra operadores estratégicos, el sector transporte fue afectado en el 14% de ellos, situándose como el segundo sector más atacado de España, tan solo por detrás de la banca, que acumuló el 34% (INCIBE, 2026).

A nivel europeo, la Agencia de Ciberseguridad de la Unión Europea (ENISA) reafirma la tendencia y observa que el sector transporte es el segundo más afectado de la UE, formando el 8,4% de incidentes de cibercrimen (ENISA, 2025). Este mismo informe revela que el 83,9% de los incidentes de cibercrimen dirigidos a este sector se llevaron a cabo mediante ransomware, en los que en el 60% de los casos el phishing fue el vector de entrada y la explotación de vulnerabilidades en torno al 21%. También es observable

una gran diferencia entre los subsectores, concentrando un 58,4% el aéreo, y la logística el 20,8% (ENISA, 2025).

Uno de los principales motivos por los que es una vulnerabilidad creciente es, en gran medida, debido a la convergencia IT/OT (Information Technology/Operational Technology). Antiguamente, los sistemas OT que operaban en el mundo físico del transporte estaban aislados bajo el modelo air gap, como, por ejemplo, Automatic Identification System (AIS) y el Electronic Chart Display and Information System (ECDIS) en el ámbito marítimo, el European Rail Traffic Management System (ERTMS/ETCS) y los sistemas SCADA y de enclavamiento en el ferroviario, o el Automatic Dependent Surveillance-Broadcast (ADS-B) y los sistemas de handling en el aéreo (Cichocki y Wójcik, 2025; ENISA, 2021; ENISA, 2023). Sin embargo, ante la digitalización y la búsqueda de eficiencia han interconectado esos sistemas con las redes corporativas y con Internet, ampliando la superficie de ataque y trasladando a entornos donde la disponibilidad y la seguridad física resultan críticas vulnerabilidades nacidas en el mundo IT (Cichocki y Wójcik, 2025). En consecuencia, un compromiso que tradicionalmente afectaba a la confidencialidad de los datos puede traducirse hoy en día en una disrupción operativa con consecuencias físicas, evidenciándose con la reversión a procedimientos manuales tras los ataques a puertos (Cichocki y Wójcik, 2025).

Otro motivo importante sería el contexto geopolítico, que ha consolidado el ciberespacio como un dominio central de confrontación híbrida (NTT DATA, 2026). Los conflictos prolongados, en la actualidad, han generado operaciones de espionaje, sabotaje y disrupción contra organismos e infraestructuras de los países de la UE y la OTAN, como en el caso de la guerra de Rusia contra Ucrania (NTT DATA, 2025b). En este escenario, España al ser parte de la OTAN y país de apoyo militar a Ucrania, no constituye un objetivo colateral, sino directo (CISA, 2025).

Es necesario resaltar que las ciberamenazas al transporte no son solo un fenómeno técnico, sino que constituyen manifestaciones de criminalidad organizada y transnacional, ejemplificada por el ecosistema Ransomware-as-a-Service, que opera con una lógica empresarial de maximización del beneficio, por el activismo político instrumentalizado presente en el hacktivismo y por la competencia estratégica interestatal materializada en el ciberespionaje patrocinado por Estados (CISA, 2025; Europol, 2025b; Radware, 2026). Por ende, es muy importante conocer el quién, el porqué, el cómo y el contexto de cada

actor porque es precisamente lo que distingue la inteligencia accionable del mero inventario de indicadores (Bianco, 2013).

Por lo tanto, la motivación de este Trabajo de Fin de Máster surge por la criticidad creciente del sector transporte español como objetivo de ciberamenazas heterogéneas y la ausencia de una capacidad integrada y automatizada que permita anticiparlas, ya que es necesario dotar al sector de un instrumento que convierta la inteligencia en detección y respuesta tempranas (ENISA, 2025; INCIBE, 2026).

1.2 Planteamiento del problema: La dispersión de amenazas en tierra, mar y aire

El problema central abordado en este trabajo es la dispersión, debido a que la amenaza al transporte español no es homogénea ni concentrada, sino que se divide en tres problemáticas que dificultan su detección y su gestión.

Por un lado, encontramos la verticalidad. Cada medio de transporte presenta una superficie de ataque y unos sistemas críticos propios. En la vertical de tierra, la alerta conjunta de CISA, la NSA y agencias aliadas documentaron en mayo de 2025 una campaña sostenida del grupo APT28, vinculado a la Unidad 26165 del GRU ruso, contra empresas de logística y transporte de al menos trece países, en su mayoría miembros de la OTAN (CISA, 2025). En la vertical de mar, el Puerto de Vigo sufrió en marzo de 2026 un ataque de ransomware que forzó la desconexión de sus sistemas de gestión de tráfico de mercancías y la reversión de la operativa a procedimientos manuales en papel (Cichocki y Wójcik, 2025; Galicia Press, 2026). En la vertical de aire, en septiembre de 2025 se atacó a Collins Aerospace y su plataforma MUSE (NTT DATA, 2026).

Por otro lado, encontramos el tipo de actor. Añadido a la verticalidad anteriormente nombrada, operan, de forma simultánea, tres familias de actores con motivaciones, capacidades y tácticas, técnicas y procedimientos (TTPs) distintos, siendo estos los actores estatales o APT orientados al espionaje, el cibercrimen organizado bajo el modelo RaaS con motivación económica, y el hacktivismo de naturaleza ideológica (CISA, 2025; Europol, 2025b; Radware, 2026).

Por último, encontramos la dispersión por fuente de inteligencia. Los indicios de estas amenazas se encuentran diseminados en multitud de fuentes heterogéneas y de

difícil correlación, que abarcan desde los avisos de los CERT nacionales y los feeds OSINT hasta los sitios de filtración de ransomware en la red Tor, las plataformas de gestión de la superficie de ataque externa y las bases de datos de incidentes.

Por ello, tras analizar la posible variabilidad de las amenazas, surge como pregunta cómo pueden caracterizarse las ciberamenazas específicas del sector transporte español, por actor, motivación y vector, y articularse un sistema de ciberinteligencia y detección automatizada que convierta esa caracterización en capacidad operativa de anticipación.

1. 3 Objetivos

1.3.1 Objetivo general

Analizar el panorama de grupos de ciberamenazas que operan contra el sector del transporte y la logística en España durante el periodo 2025-2026 y diseñar e implementar un sistema de ciberinteligencia y detección automatizada que, integrando inteligencia de fuentes abiertas, permita la identificación temprana y la alerta proactiva de amenazas dirigidas a las verticales de tierra, mar y aire.

1.3.2 Objetivos específicos

1. Caracterizar el panorama de ciberamenazas del sector transporte español, diferenciando las verticales de tierra, mar y aire y los sistemas IT/OT críticos de cada una, e identificando los vectores de ataque predominantes.
2. Elaborar una taxonomía de actores de amenaza que distinga los actores estatales (APT), el cibercrimen organizado (RaaS) y el hacktivismo, atendiendo a su motivación, sus capacidades y sus TTPs mapeadas sobre el marco MITRE ATT&CK, y contrastar dicha taxonomía con una caracterización empírica OSINT de actores activos en Telegram.
3. Diseñar la arquitectura de un sistema de inteligencia y detección automatizada basado en software de código abierto, justificando la selección tecnológica de MISP como plataforma de inteligencia, Wazuh como SIEM/XDR y la API de Telegram como canal de alerta, en función de los requisitos del sector y del marco normativo de la Directiva NIS2

4. Implementar y validar el sistema mediante el desarrollo de los módulos de ingesta automatizada de OSINT, Dark Web, gestión de la superficie de ataque y bases de datos de incidentes, su integración Wazuh-MISP, la automatización de la generación de reglas de detección a partir de la inteligencia recopilada, y su evaluación a través de casos de uso representativos.

5. Desarrollar e integrar un agente de generación automática de reglas de detección basado en un modelo de lenguaje de gran escala (LLM), capaz de traducir informes de inteligencia de ciberamenazas (CTI) en reglas nativas de Wazuh, incorporando un punto de control humano previo a su despliegue automatizado mediante la API REST del gestor.

1.4 Alcance

El alcance del trabajo abarca las ciberamenazas dirigidas al sector del transporte y la logística en España, entendido en sentido amplio, comprendiendo el transporte terrestre, el marítimo, el aéreo y la cadena de suministro asociada. El ámbito temporal del análisis comprende el periodo 2025-2026, con especial énfasis en los datos más recientes, correspondientes al segundo semestre de 2025 y al primer semestre de 2026.

1.5 Estructura del documento

El presente trabajo se divide en:

- El estado del arte y marco teórico: se caracterizan las ciberamenazas del sector transporte, se establece la taxonomía de actores y se instauran los fundamentos de la ciberinteligencia.
- El análisis estadístico de actores vía Telegram y la posterior generación de reglas de detección para estos actores mediante el Agente IA
- La metodología y arquitectura de la solución: se expone el diseño de la investigación y justifica la selección tecnológica de Wazuh, MISP y la API de Telegram, presentando la arquitectura propuesta y el esquema de integración Wazuh-MISP.

- El despliegue e implementación técnica: se detallan el entorno de pruebas virtualizado, el despliegue de MISP, la suscripción a feeds y taxonomías del sector, la integración para la consulta automatizada de IOCs y el desarrollo de los scripts de ingesta y de la lógica de alertado por Telegram.
- El desarrollo de un agente de generación automática de reglas de detección para Wazuh a partir de informes de inteligencia de ciberamenazas mediante un modelo de lenguaje de gran escala (LLM).
- Las limitaciones, las líneas de trabajo futuro y las conclusiones donde se recogen los hallazgos principales, seguidas de la bibliografía, la legislación y los anexos.

2. Estado del arte y marco teórico

2.1 Ciberamenazas en el Sector Transporte

Particularmente, el sector transporte se distingue de otros objetivos de la ciberdelincuencia debido a la coexistencia de extensos entornos de tecnología de información con tecnologías de operación que llevan a cabo procesos físicos de altísima criticidad (Cichocki y Wójcik, 2025). Como se ha señalado anteriormente, la digitalización, la automatización y la búsqueda de eficiencia, han aumentado notablemente la superficie de ataque y han sido expuestos sistemas que durante décadas operaban aislados (Cichocki y Wójcik, 2025). Este suceso se ve respaldado por los datos de ENISA, que se han comentado en la introducción, sobre la elevada presencia de ataques basados en ransomware en contra del sector. También, es importante comentar que esta exposición técnica se ve agravada a menudo por el factor humano, ya que, como se observa en los informes del Coast Guard Cyber Command estadounidense, en el sector marítimo, el phishing fue el vector de acceso inicial principal, sumando tasas de éxito del 66% en 2023 y del 53% en 2024, y con tasas de éxito de los ataques de fuerza bruta sobre contraseñas superiores al 47% (Cichocki y Wójcik, 2025). Además, hay que tener en cuenta que estas amenazas al sector no son nuevas puesto que entre julio de 2022 y junio de 2023, el transporte europeo registró 192 incidentes y advirtió de un repunte en los ataques de denegación de servicio protagonizados por grupos hacktivistas prorrusos, siendo una clara demostración de la importancia que tiene la ciberinteligencia como método para anticipar las amenazas, y no solo como una respuesta a posteriori (ENISA, 2023). A continuación, se caracterizan las amenazas presentes en cada vertical.

2.1.1 Vertical Tierra: Logística, flotas y sistemas ferroviarios

La vertical terrestre reúne el transporte de mercancías por carretera, la gestión de flotas, la logística intermodal y el ferrocarril, y es probablemente la de mayor superficie de exposición por su densidad de actores y su elevada digitalización (ENISA, 2025). En el plano logístico, los sistemas de gestión de transporte (TMS), de gestión de almacenes (WMS), las pasarelas de telemática de flotas, los dispositivos de registro electrónico como el tacógrafo digital y las plataformas de emparejamiento e intermediación de carga constituyen una superficie de ataque atractiva tanto para el fraude en línea como para la disrupción operativa derivada del ransomware (Europol, 2025b; Villadsen et al., 2025).

A nivel ferroviario los sistemas críticos son de naturaleza OT e incluyen ERTMS/ETCS de señalización y control, los enclavamientos, el Control de Tráfico Centralizado y los sistemas SCADA de catenaria y energía (ENISA, 2021).

Las amenazas sobre esta vertical son diversas, siendo la más frecuente el RaaS, donde grupos como Qilin o Akira han atacado de forma frecuente a operadores logísticos españoles, con víctimas confirmadas como Operinter, Avitrans, Grupo Ruiz o Maresa Logística (Ransomware.live, 2026; DeXpose, 2026a; DeXpose, 2026b). Por otro lado, se encuentra la amenaza estatal (APT), cuyo seguimiento presenta una mayor dificultad al resto de amenazas, sin embargo, se conoce un caso relevante en el que CISA y la NSA documentaron un ataque de APT 28 en mayo de 2025 a una cadena de logística de apoyo a Ucrania en países de la OTAN, llegando a comprometer sistemas ICS ferroviarios y cámaras IP en hubs y pasos fronterizos para monitorizar físicamente los envíos, mediante TTPs que combinaron la explotación de vulnerabilidades en Outlook, Roundcube y WinRAR, el spear-phishing, la fuerza bruta y el uso de routers SOHO como proxy (CISA, 2025). Además, esta campaña recurrió a malware a medida como HEADLACE y MASEPIE (CISA, 2025). Por el contrario, es importante tener en cuenta el rigor analítico al analizar estos ataques, siendo necesario distinguir el ciberataque del fallo técnico, ya que se han dado varios incidentes que pueden llevar a confusión, como es el caso de Adif y Renfe que sufrieron la caída de cerca de trescientos servidores que paralizaron la alta velocidad desde Madrid en septiembre de 2025 o el bloqueo del Centro de Tráfico Centralizado de Barcelona en enero de 2026, que fueron investigados y finalmente atribuidos a errores de IT o a problemas de alimentación eléctrica, y no a una acción hostil, por lo que documentar estos descartes es tan relevante para la rigurosidad del análisis como confirmar los incidentes reales (elDiario.es, 2025; Tinku, 2026).

2.1.2 Vertical Mar: Sistemas de navegación y puertos inteligentes

La vertical marítima combina dos superficies de ataque distintas, la del buque y la del puerto. En el primero, los sistemas de mayor criticidad son el GNSS de navegación por satélite, el AIS de identificación automática, el ECDIS de cartografía electrónica, el Vessel Traffic Service de control del tráfico marítimo y los sistemas SCADA de propulsión y carga (Cichocki y Wójcik, 2025). En el segundo, la criticidad se encuentra en torno al Port Community System, que integra a la autoridad portuaria, las terminales,

las aduanas y los transitorios, además de los sistemas de gestión de terminales y de grúas (ENISA, 2019).

Por un lado, los buques suelen ser amenazados mayoritariamente por GPS spoofing y jamming. Uno de los casos de más renombre es el del portacontenedores MSC Antonia, que encalló en mayo de 2025 cerca del puerto de Jeddah debido a que su sistema AIS fue engañado por señales GPS falsas, mostrando el potencial disruptivo de esta técnica (Cichocki y Wójcik, 2025). Además, otros ejemplos como los episodios de falsificación de AIS en el Mar Negro durante el conflicto entre Rusia y Ucrania en mayo de 2023, que hicieron que varios buques vieran alterada su posición hacia la Crimea ocupada por Rusia, observándose localizaciones simuladas y dispuestas en forma de la letra Z, asociada a las fuerzas rusas, demuestran la dimensión geopolítica de esta amenaza (Cichocki y Wójcik, 2025).

Por otro lado, la amenaza principal contra los puertos es el ransomware, capaz de detener las funciones físicas a partir de una intrusión IT. Un ejemplo que muestra con claridad las amenazas en esta vertical es el ataque al puerto de Nagoya en 2023, el mayor de Japón, atribuido al grupo Lockbit 3.0, que paralizó durante casi tres días el sistema unificado de terminales que gestiona la carga y descarga de contenedores (Cichocki y Wójcik, 2025). A nivel español se encuentra el ataque de ransomware al Puerto de Vigo en marzo de 2026, en el que se forzó el aislamiento de los sistemas de gestión de tráfico de mercancías y la reversión a procedimientos manuales en papel, sin que las operaciones físicas de movimiento de buques se detuvieran y sin que se negociara ni pagara rescate alguno, como confirmó la propia autoridad portuaria (Galicia Press, 2026; Cadena de Suministro, 2026). A todo esto, se le suma el interés sostenido de actores estatales por la logística marítima, atribuido a grupos de nexo chino como Mustang Panda, APT41 y UNC5221 (ENISA, 2025).

2.1.3 Vertical Aire: Control aéreo y sistemas aeroportuarios

Según ENISA (2025), la aérea es la vertical más atacada del sector en Europa, contando con el 58,4% de los incidentes y, además, presenta una superficie de ataque especialmente sensible por su criticidad para la seguridad de las personas y por su elevada interdependencia. En este sector los sistemas relevantes que pueden verse afectados incluyen el ADS-B y el ACARS en la comunicación y la vigilancia, los sistemas de

gestión de vuelo, los sistemas de reserva de aerolíneas operados por proveedores como Amadeus y, en tierra, los sistemas aeroportuarios de check-in, embarque y tratamiento de equipajes (ENISA, 2016; Habler et al., 2023).

Concretamente, la amenaza que más se da en esta vertical es el ataque a la cadena de suministro, derivada de la fuerte concentración de proveedores tecnológicos, como ocurrió en el incidente de 2025 contra Collins Aerospace y su plataforma MUSE, que gestiona el handling de diversas aerolíneas y aeropuertos, lo que provocó disrupciones en cascada en aeropuertos como Londres-Heathrow, Bruselas y Berlín-Brandeburgo a partir de un único punto de compromiso, mediante una variante del ransomware HardBit (NTT DATA, 2026; Cybersecurity Dive, 2025). Además, aunque Aena confirmó que los aeropuertos españoles operaron con normalidad, el episodio mostró que la resiliencia del sector nacional no depende de este, sino que depende de sus proveedores tecnológicos comunes, lo que motivó a una inversión, por parte de Aena, de 62 millones de euros a ciberseguridad (Ministerio de Transportes, 2025; El Mercantil, 2025). A esta amenaza se añaden el ransomware contra aerolíneas como ocurrió con el incidente de Iberia por parte del grupo Everest en noviembre de 2025 (Ransomware.live, 2026), y el ciberespionaje estatal como el de APT33, de nexo iraní, que muestra un gran interés en la aviación y el sector aeroespacial (MITRE Corporation, s.f.; Microsoft Threat Intelligence, 2024).

2.2 Taxonomía de Actores de Amenaza (Threat Actors)

La caracterización de una amenaza exige, antes que el inventario de sus técnicas, la comprensión de quién está detrás y por qué actúa. Sobre esta premisa, se distinguen tres grandes familias, los actores estatales, el RaaS y el hacktivismo.

También es destacable la existencia de insiders, pudiéndose generar amenazas críticas por parte de empleados, contratistas o proveedores. Los insiders se pueden dividir en maliciosos, que actúan de forma deliberada por venganza o beneficio, y negligentes, que provocan una brecha por error o por incumplimiento de las políticas de seguridad (CISA, 2020). Este grupo tiene una especial relevancia debido a que el sector transporte cuenta con cadenas de suministro y de subcontratación muy complejas, por lo que el control del acceso de terceros y la concienciación del personal constituyen factores de gran importancia. Esto explicaría por qué el abuso de identidades y credenciales legítimas se ha consolidado como uno de los vectores de acceso inicial más difíciles de detectar, ya

que no genera las alertas asociadas al despliegue de malware, mismo motivo por el que en el desarrollo de este trabajo no es viable incluirlo, pero se ha de tener presente (IBM, 2026).

Antes de desarrollar cada familia de actores, cabe destacar una asimetría entre estos, ya que los grupos RaaS están muy documentados, pero los APT y los hacktivistas solo lo están en informes agregados. Esta idea se desarrolla en profundidad en el capítulo Limitaciones.

2.2.1 Actores Estatales (APT) y ciberespionaje industrial

Las Amenazas Persistentes Avanzadas son actores patrocinados o tolerados por un Estado, cuya motivación es geopolítica e incluye el espionaje estratégico e industrial, el pre-posicionamiento en infraestructuras críticas para una eventual disrupción y la proyección de poder por debajo del umbral del conflicto armado (NTT DATA, 2026). Estos actores se caracterizan por su sofisticación, sus recursos y, principalmente, su persistencia y su sigilo, además de centrarse en mantener el acceso a largo plazo más que en el impacto inmediato (NTT DATA, 2026).

En lo que al transporte se refiere, podemos identificar tres nexos principales. En primer lugar, encontramos el nexo ruso, el más activo contra Europa, donde se observan APT28, también conocido como Fancy Bear o Forest Blizzard y vinculado a la Unidad 26165 del GRU, que lidera el espionaje a la logística de apoyo a Ucrania; el grupo Gamaredon que mantuvo una elevada actividad de spear-phishing contra entidades europeas; y APT44 (Sandworm) que aporta capacidad destructiva mediante malware de tipo wiper en el marco de la guerra híbrida, como ocurrió en el segundo semestre de 2025, desplegando wipers como ZEROLOT y Sting contra sectores críticos como la logística (CISA, 2025; NTT DATA, 2026).

En segundo lugar, el nexo chino está orientado al espionaje industrial y económico de largo plazo, manifestándose en grupos como Mustang Panda y APT41, que poseen un especial interés por la logística marítima y la movilidad inteligente, mostrando en el segundo semestre de 2025, una diversificación de sus campañas al enfocar sus objetivos hacia el transporte, los gobiernos y la manufactura, priorizando operaciones de inteligencia con ciclos operativos largos (ENISA, 2025; NTT DATA, 2026)

Por último, el nexo iraní, que cuenta con grupos como APT33, orientado a la aviación, y MuddyWater, que ha mantenido campañas sostenidas contra infraestructura marítima energética de Oriente Medio y ha expandido su actividad hacia Europa desde 2025 (Group-IB, s.f.; MITRE Corporation, s.f.; Unit 42, 2026).

En lo que a España se refiere, el riesgo es directo, pues ENISA (2025) indica que la actividad de APT28 contra el transporte se enmarca en la estrategia de Moscú de atacar la infraestructura crítica de los aliados de la OTAN, por su apoyo a Ucrania.

2.2.2 Ransomware-as-a-Service (RaaS)

El RaaS es la amenaza más presente y su motivación es únicamente económica, es decir, un ecosistema industrializado del delito en el que los operadores desarrollan y mantienen la infraestructura, incluyendo el ransomware, los sitios de filtración y la negociación, además de alquilar el ransomware a una red de afiliados a cambio de una comisión (Europol, 2025b; NTT DATA, 2026). Este modelo sumado a los Initial Access Brokers, que venden los accesos iniciales, a los infostealers, que proveen las credenciales, explica la escala y la resiliencia del fenómeno, ya que la desarticulación de un grupo no reduce el volumen global, sino que redistribuye a sus afiliados hacia otras marcas, como ocurrió tras la desaparición de RansomHub en abril de 2025, cuyos afiliados migraron mayormente a Qilin (NTT DATA, 2025a; SOCRadar, 2026).

El modus operandi de estos grupos ha evolucionado del cifrado a la doble extorsión, es decir, que combina el cifrado con la amenaza de publicación de los datos robados (NTT DATA, 2026; Unit 42, 2025). Durante el tercer trimestre de 2025, se contabilizaron una media de 535 víctimas mensuales, habiendo sido publicadas en sitios de filtración 1.592 víctimas, coexistiendo al menos 85 grupos de ransomware activos, la cifra más alta registrada hasta la fecha, además de que el ransomware estuvo implicado en aproximadamente el 44% de las brechas de seguridad de 2025, frente al casi 32% en 2024 (NTT DATA, 2026).

En concreto, los grupos más activos contra España en 2025 fueron Qilin, responsable del 17,8% de los ataques, y Akira, con el 11,2%, ambos con víctimas confirmadas en el sector logístico (SOCRadar, 2026). El análisis de las víctimas españolas publicadas en ransomware.live durante 2025 y 2026 mantiene el orden de 2025, siendo primera Qilin y segunda Akira, además de revelar víctimas concretas de la categoría de

transporte y logística española como Air Europa, Iberia, Maresa Logística, Grupo Ruiz, Operinter y Avitrans (Ransomware.live, 2026; DeXpose, 2026a; DeXpose, 2026b). Otros actores de impacto relevante serían Cl0p, especializado en la explotación masiva de vulnerabilidades zero-day en software de transferencia de ficheros, con gran impacto en la cadena de suministro; Play, de volumen constante; y Everest, responsable del ataque al grupo Iberia (Ransomware.live, 2026). Es importante resaltar que la tendencia de estos grupos es la fragmentación del ecosistema, la profesionalización de la extorsión basada en datos y el uso creciente de la inteligencia artificial como acelerador operativo (NTT DATA, 2026).

2.2.3 Hacktivismo

El hacktivismo está formado por actores cuya motivación es ideológica o política, y su técnica preferida es el DDoS, complementada con defacements y filtraciones selectivas, teniendo como principal objetivo la búsqueda de visibilidad, la presión simbólica y el impacto reputacional (Radware, 2026). Este fenómeno se ha convertido en un ecosistema organizado que se coordina a través de más de cuatrocientos canales de Telegram y articulado en torno a campañas con hashtag, en el que algunos grupos operan como si fueran influencers, proyectando su marketing de afiliación con los proveedores de DDoS-as-a-Service (Radware, 2026). El actor de referencia es el grupo prorruso NoName057(16), responsable de 4.692 reivindicaciones de ataque en 2025, lo que lo convierte en el actor hacktivista con mayor impacto de la historia, contando con un 30,5% de los ataques DDoS de red (Radware, 2026). NoName057(16) ha conseguido este impacto mediante su herramienta de DDoS distribuido, llamado DDoSia, y un modelo de voluntariado ludificado (Europol, 2025a). Particularmente, España ha sido objetivo prioritario a través de la campaña #OpSpain, la cuarta operación hacktivista más mencionada del planeta con 833 menciones, de una venganza debida a su apoyo a Ucrania, dándose ataques a instituciones, transporte y empresas tecnológicas. También, hay que resaltar que, en diversas ocasiones, colaboran con grupos afines como Mr.Hamza o TwoNet (Radware, 2026). En el ámbito nacional, Anonymous Fénix sería el ejemplo perfecto para explicar que el hacktivismo también puede ser de motivación interna, grupo que efectuó ataques DDoS a webs gubernamentales tras la gestión de la DANA de Valencia en 2024 (Guardia Civil, 2026; Help Net Security, 2026).

2.3 Casos confirmados en el sector transporte español (2025-2026)

Este apartado ofrece evidencia empírica recopilada sobre incidentes reales en contra del transporte español, que ha sido obtenida a partir del cruce de fuentes estructuradas, como ransomware.live y EuRepoC, con informes institucionales, como INCIBE, ENISA y SOCRadar. Esta recopilación ha sido realizada con el fin de demostrar, con casos concretos y verificables, el panorama descrito en los apartados anteriores, teniendo en cuenta la asimetría existente entre la evidencia del RaaS, documentado de forma amplia, y los ataques APT y hacktivistas, cuya visibilidad se encuentra más reducida en fuentes abiertas.

2.3.1 RaaS

Según el Spain Threat Landscape Report de SOCRadar, Qilin y Akira son los grupos de ransomware más presentes contra España, con el 17,8% y el 11,2% de los incidentes totales respectivamente. A estos dos grupos los sigue Ransomhub (desaparecido en 2025) con el 4,1%. Sin embargo, el 66,9% restante se reparte entre numerosos grupos de baja actividad (SOCRadar, 2026).

La veracidad de esta fuente ha podido ser comprobada mediante el análisis directo de la API de ransomware.live, desde enero de 2025 hasta julio de 2026, identificando 268 víctimas españolas encabezadas por los grupos Qilin, con 58, y Akira, con 19 (Ransomware.live, 2026). Seguido de esto, se filtró por el sector transporte y logística, además de incluir, tras revisión manual, aquellos casos cuya actividad figuraba como 'Not Found' (en actores y en víctimas).

Los siguientes gráficos, realizados con los datos de ransomware.live, muestran porcentualmente los grupos RaaS que más atacaron el sector transporte en el tiempo estipulado, además de indicar a qué subsector pertenecían las víctimas.

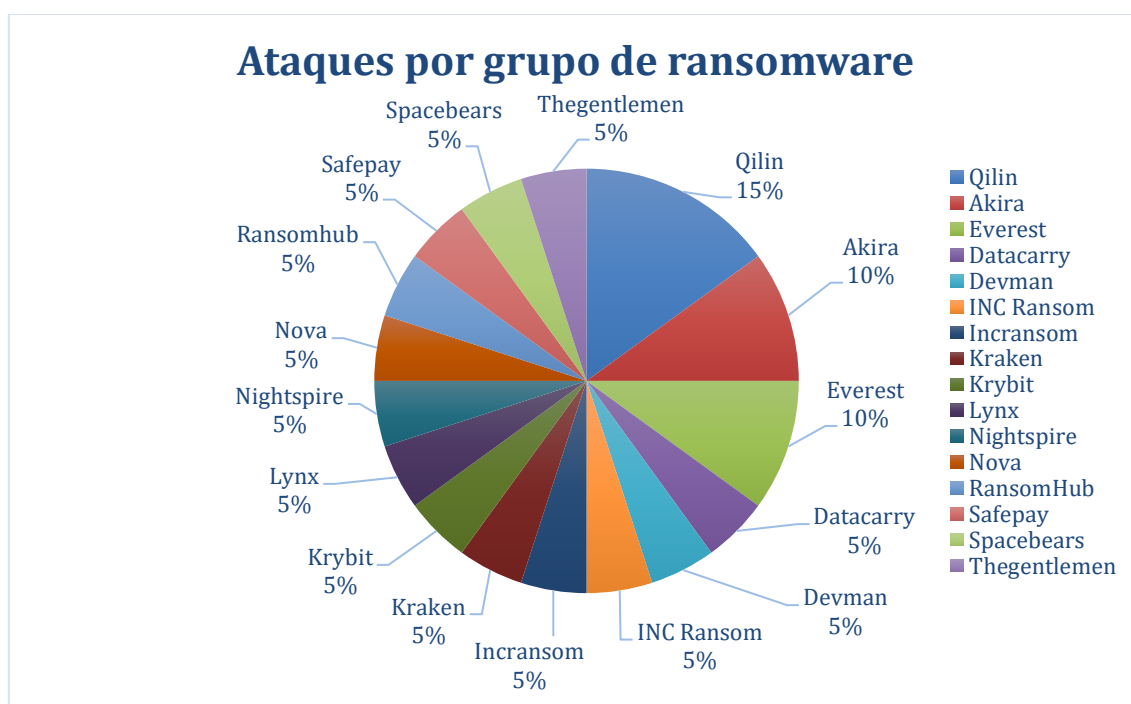


Fig. 1. Elaboración propia. Ataques contra el sector transporte español (Ransomware.live, 2026)

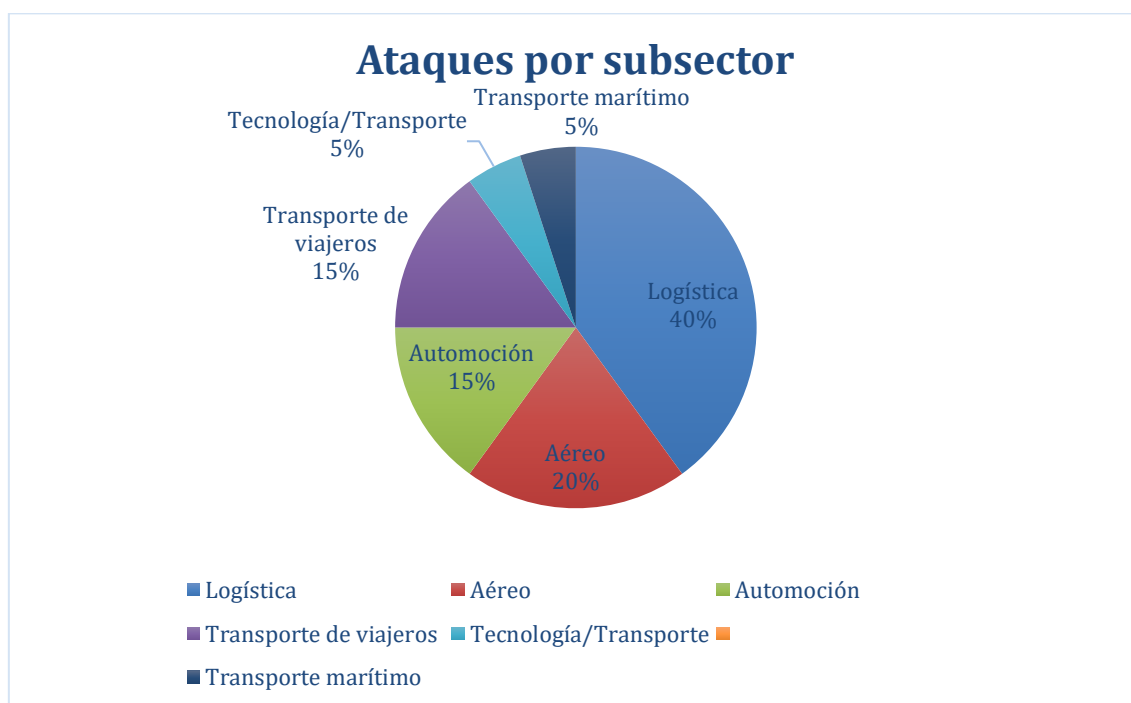


Fig. 2. Elaboración propia. Subsectores atacados (Ransomware.live, 2026)

Estos datos confirman el predominio de Qilin, Akira y Everest como actores RaaS, y el mayor impacto en los subsectores logístico y aéreo (Ransomware.live, 2026).

Por otro lado, también es inteligencia de valor aquellos datos obtenidos a nivel europeo, ya que a nivel de prevención pueden ser de gran utilidad. Por lo tanto, es importante destacar los matices observados en el informe ENISA, que afirma que los incidentes de cibercrimen contra el transporte supusieron el 8,4% de todos los casos de

ciberdelincuencia contra la UE, con el ransomware como modalidad dominante con un 83,9%, frente a las brechas de datos con un 16,1%. Además, si existen diferencias respecto a los actores ya que en primer lugar se encuentra Akira con un 12,9%, y, empatados en segundo lugar, INC Ransom con un 9,7%, y Cl0p con un 9,7%. También, es importante destacar que España figuró como el tercer Estado miembro más referenciado en reivindicaciones de ransomware y brechas con un 9,8%, por detrás de Alemania e Italia con un 23,4% y un 11,3%, respectivamente (ENISA, 2025).

2.3.2 Hacktivismo

La corriente hacktivista en contra del transporte español está dominada por grupos prorrusos. A nivel europeo ENISA confirma que el transporte fue uno de los sectores más golpeados por el DDoS hacktivista, que representó el 87,6% de los ataques contra el sector siendo NoName057(16) el más activo, con el 36,4%, seguido de Dark Storm Team, con el 15,4%, y Mysterious Team Bangladesh, con el 6,2% (ENISA, 2025). Este informe también revela que el transporte fue el segundo sector más afectado por DDoS hacktivista en Europa, con un 12%, tan solo por detrás de la administración pública, que cuenta con el 63,1% (ENISA, 2025). Concretamente en España y como se comentó antes, la intensidad de estos ataques quedó patente en marzo de 2025 con la campaña #OpSpain de NoName057(16), sumando más de 500 ataques contra España desde 2022, sin embargo, no se han encontrado fuentes que reúnan, en específico, una amplia estadística de los ataques contra el transporte español (Radware, 2026; Europol, 2025a).

Donde sí se ha podido recoger una reducida muestra ha sido mediante EuRepoC, con tres ataques:

Fecha	Víctima	Grupo	Tipo
2025-03-03	EMT Ciudad Real	NoName057(16)	DDoS
2025-03-07	AUVASA Valladolid	NoName057(16)	DDoS
2025-03-07	Concello de Vigo	TwoNet	DDoS

Tabla 1. Datos obtenidos de EuRepoC (2026)

Estos datos muestran una falta de plataformas de fuentes abiertas actualizadas que traten esta problemática, ya que con una simple investigación en Telegram de grupos abiertos, mediante Google Dorking, se obtuvo una cantidad mayor de resultados positivos comprobados manualmente, como se puede observar en el siguiente capítulo y en el

Anexo II, que recoge tres capturas representativas de estas reivindicaciones, siendo ya más información que la proporcionada por EuRepoC.

Por ello, como se comenta en el capítulo limitaciones, debe señalarse que estos canales de Telegram evidencian un volumen de ataques confirmados muy superior al recogido en este trabajo, pero no se pudo monitorizar de forma automática.

2.3.3 Amenaza estatal (APT)

En cuanto a los ataques realizados por APT, no se encontró la existencia de fuentes abiertas que documentaran de forma granular estas actividades, sin embargo, existen informes institucionales que permiten establecer una visión orientativa de los principales actores, como se observa en el informe de ENISA. Este informe cuantifica en un 4,1% la proporción del transporte de la Unión Europea atacado por actores de nexos estatal, dominado por los nexos chino y ruso, que suman el 46,7%, destacando Mustang Panda, UNC5221 y APT41 por parte de china, y APT28 por parte de Rusia (ENISA, 2025). También es relevante la actividad del grupo norcoreano, Lazarus Group (ENISA, 2025).

Este análisis está corroborado por el informe de actividad APT de ESET correspondiente al periodo de abril a septiembre de 2025, en el que podemos encontrar que el nexo chino dirigió su actividad, entre otros, al transporte marítimo, mientras que el nexo ruso se enfocó en la logística de la Unión Europea y Canadá, también entre otros (ESET, 2025).

2.4 Fundamentos de Ciberinteligencia (CTI)

Una vez determinadas las amenazas y sus actores, se va a establecer el marco conceptual de la ciberinteligencia que sustenta la solución propuesta. La CTI es un proceso orientado a producir conocimiento accionable que reduzca la incertidumbre en la toma de decisiones de seguridad, transformando datos dispersos en inteligencia útil.

2.4.1 Ciclo de vida de la inteligencia

La producción de inteligencia se estructura en el ciclo de inteligencia, compuesto por cinco fases. En primer lugar, la planificación y dirección, que define los requisitos y las necesidades, siendo las amenazas al transporte español. En segundo lugar, la recopilación y obtención, enfocada en recoger los datos de las fuentes disponibles, como

los feeds OSINT, la Dark Web o las plataformas de gestión de la superficie de ataque. Posteriormente, se encuentra el procesamiento y explotación, donde se normalizan y estructuran los datos en bruto. Al procesamiento y explotación le sigue el análisis y producción de inteligencia, que convierte los datos en bruto en inteligencia mediante evaluación, correlación y contextualización. Por último, se encuentra la difusión, que entrega la inteligencia a quien debe actuar. También se puede dar una sexta fase, la retroalimentación, que ajusta el ciclo a partir de la respuesta del consumidor (DKS, 2026)

El sistema propuesto en este trabajo materializa el ciclo completo, pues sus módulos de ingesta recolectan la información de fuentes dispersas, MISP la procesa y la correlaciona, y la integración con Wazuh y Telegram difunde la inteligencia en una alerta accionable.

2.4.2 Estándares de intercambio (STIX/TAXII)

Para que la inteligencia sea compatible y automatizable, debe expresarse en un lenguaje común. Los estándares de referencia son STIX (Structured Threat Information eXpression), un lenguaje que modela de forma estructurada los objetos de la inteligencia de amenazas, recogiendo indicadores, actores, campañas, TTPs y sus relaciones, y TAXII (Trusted Automated eXchange of Indicator Information), el protocolo de transporte que permite el intercambio automatizado de esa información entre plataformas (OASIS, 2021). Esta elección es lo que permite que las organizaciones y los CERT compartan inteligencia de forma interoperable y a la velocidad que exige la amenaza.

Teniendo presente este contexto, MISP actúa como plataforma de inteligencia de referencia, ya que almacena los eventos e indicadores de forma estructurada, soporta la sincronización entre instancias y emplea taxonomías normalizadas para clasificar la información por sector, país o nivel TLP, lo que resulta especialmente valioso.

2.4.3 Frameworks de referencia (MITRE ATT&CK y Pyramid of Pain)

El análisis del comportamiento adversario se apoya en marcos de referencia consolidados como MITRE ATT&CK, que cataloga, a partir de observaciones, las tácticas, entendidas como el objetivo del adversario, como el acceso inicial, la persistencia, la exfiltración o el impacto, y las técnicas, entendidas como el modo concreto de conseguirlo. La importancia de este framework es de especial relevancia,

pues proporciona un lenguaje común para describir los TTPs y permite mapear la cobertura defensiva de una organización. Concretamente, MITRE ATT&CK for ICS es especialmente relevante para el sector transporte, ya que da cobertura a la dimensión OT de la amenaza (MITRE Corporation, s.f.). La utilidad operativa de este marco se refleja en el sistema propuesto, cuyo módulo de perfilado de actores extrae y asocia a cada grupo sus técnicas catalogadas en ATT&CK.

Otro marco complementario sería la Pyramid of Pain, ya que jerarquiza, según el coste y la dificultad, los indicadores que permiten identificar al atacante (Bianco, 2013). En la base de la pirámide encontramos los indicadores triviales de modificar, como los hashes de fichero, las direcciones IP y los nombres de dominio, y en la cima encontramos las TTPs, cuya detección obliga al adversario a rediseñar su *modus operandi*, lo que resulta muy costoso (Bianco, 2013). Por ende, se concluye que una defensa madura no debe limitarse a bloquear indicadores atómicos de fácil reemplazo, sino que debe aspirar a detectar comportamientos.

A estos dos marcos se añaden, como modelos analíticos de apoyo, la Cyber Kill Chain, que descompone la intrusión en fases secuenciales (Hutchins et al., 2011), y el Modelo Diamante, que relaciona al adversario, su capacidad, su infraestructura y la víctima (Caltagirone et al., 2013), ambos útiles para estructurar el análisis de cada incidente.

3. Análisis estadístico de actores vía Telegram y desarrollo de Reglas Wazuh

Tras haber establecido el marco teórico, en este capítulo se podrá observar el análisis de diversos actores vía Telegram, lo que ofrece una visión más detallada que la ofrecida por las fuentes abiertas de recolección analizadas en el capítulo anterior, para posteriormente formular reglas de detección Wazuh para estos actores, mediante el Agente IA que será explicado al detalle más adelante.

3.1 Caracterización de los actores como método de partida

Para fundamentar la selección de actores y de comportamientos a detectar, se realizó un estudio estadístico OSINT de los principales grupos hacktivistas prorrusos.

El estudio se organizó en tres agrupaciones: Blacknet-00, ZPENTEST ALLIANCE y APK (AvangardSec / pol4rity / KIDS). También, se midió el alcance y nivel de interacción de cada canal, empleando las cifras oficiales de agregadores públicos como Telemetr.io y TGStat, en los casos que existían, y, debido a la imposibilidad de analizar manualmente todas y cada una de las publicaciones, en los casos que no se encontró ni Telemetr.io ni TGStat, se calcularon a mano a partir de varias publicaciones, haciendo que fueran más inexactas las estadísticas de algunos grupos. Todo ello se obtuvo respetando el OSINT/OPSEC, es decir, sin acceder a Telegram con cuenta propia, solo mediante los chats y agregadores consultados desde un navegador aislado.

De este análisis se extrae una conclusión principal, el material de estos canales es rico en identidades y reivindicaciones, pero pobre en indicadores técnicos accionables, por lo tanto, las reglas de detección no pueden derivarse del volcado en crudo, sino que es necesario desarrollar informes de inteligencia destilados a partir de él y enriquecerlos con información pública de otros informes.

El análisis estadístico completo se recoge en el Anexo III, donde se encuentra el hipervínculo al Excel “Estadísticas Telegram”.

3.2 De la inteligencia a la detección: reglas obtenidas

3.2.1 Procedimiento de generación y validación

Las reglas se obtuvieron mediante el agente de generación automática desarrollado como contribución técnica en este trabajo (descrito en detalle en su capítulo correspondiente). El procedimiento empieza con el desarrollo de un informe técnico destilado a partir de lo observado en las conversaciones de los canales de Telegram accesibles, sumado al conocimiento extraído de fuentes públicas al respecto (CERT-UA, 2026; Chiapetta, 2026; CrowdStrike Falcon Sandbox, 2026; IANA, 2026; SEC-1275-1, 2026). Una vez desarrollado el informe, este se le entrega al agente, que produce una regla de detección en formato Wazuh.

Siguiendo la Pyramid of Pain (Bianco, 2013) comentada antes, se priorizó la detección de comportamientos (TTP) sobre la de indicadores volátiles, y cada regla se referenció a la técnica correspondiente de MITRE ATT&CK.

El conjunto resultante consta de 13 reglas de detección, organizadas en tres grupos que se corresponden uno a uno con los tres informes sobre las tres agrupaciones. Por integridad académica, las reglas que en una fase previa se habían derivado únicamente de nombres e indicadores reposteados en los canales de Telegram, fueron eliminadas del conjunto, conservándose solo las que se sustentan en TTPs documentados.

3.2.2 Archivo Blacknet-00 (BLACKNET-00 y TRK25 SCADA)

Durante el análisis OSINT de hacktivistas prorrusos, elegidos por su gran impacto como se vio en el marco teórico, se encontró la colaboración entre un grupo hacktivista iraquí, llamado 313 Team, y un grupo RaaS, llamado Infrastructure Destruction Squad, de procedencia china y con ningún interés en atacar a su país. Por el contrario, ataca aquellos países que ataquen China, por lo que parece un grupo híbrido, entre RaaS y APT. Este ejemplo se eligió porque muestra la variabilidad de los grupos y cómo los límites que separan hacktivistas, RaaS y APT, no son siempre fijos.



Fig. 3. Telemetr.io Infrastructure Destruction Squad



Fig. 4. Telemetr.io Infrastructure Destruction Squad



Fig. 5. Vía Telegram. Infrastructure Destruction Squad

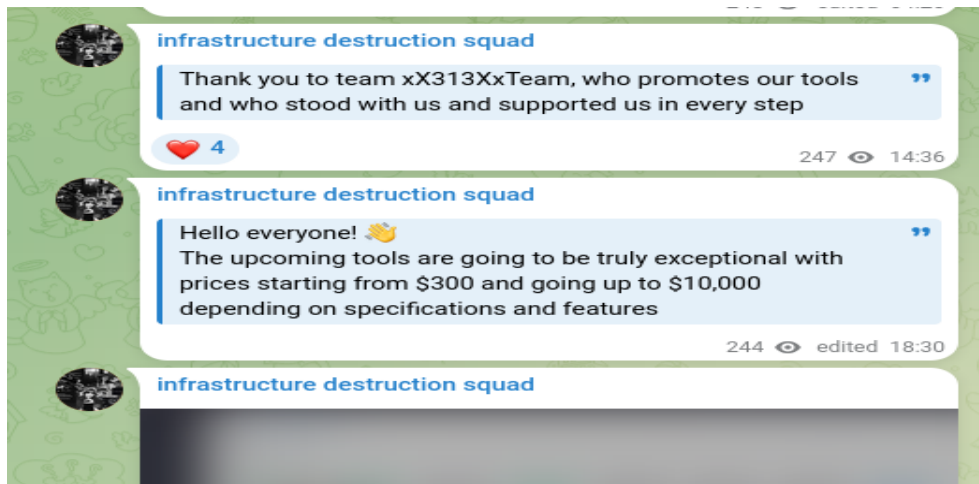


Fig. 6. Vía Telegram. Infrastructure Destruction Squad

El grupo RaaS chino, recoge en sus conversaciones el ciclo de vida del ransomware BlackNet-00, empaquetado en Python con PyInstaller, y la actividad de la herramienta TRK25 contra sistemas de control industrial, especialmente vulnerable en el sector transporte, como se vio a lo largo del marco teórico. Las reglas obtenidas, tras realizar el informe sobre esta agrupación, operan sobre endpoints Windows monitorizados con Sysmon.

-Regla 100001: BlackNet-00 (empaquetado con PyInstaller) se autoextrae en una carpeta `_MEI` del TEMP y deja el intérprete `python313.dll`. La regla detecta la creación de ese artefacto (Sysmon EventID 11).

-Regla 100002: detecta la creación de un fichero cifrado `.enc` o de la nota de rescate `READ_NOTE.html` (EventID 11), artefactos del impacto del ransomware.

-Regla 100003: el framework TRK25 interactúa con puertos industriales. La regla detecta conexiones (EventID 3) a los puertos 502 (Modbus), 102 (S7comm) o 5900 (VNC).

-Regla 100004: detecta consultas DNS (EventID 22) a dominios `.onion`, indicio de comunicación C2 sobre Tor.

Regla	Detecta	Campo / patrón	MITRE	Nivel
100001	Artefacto PyInstaller (_MEI/python313.dll)	regex · TEMP _MEI ... python313.dll	T1059.006	9
100002	Fichero .enc o nota READ_NOTE.html	regex · .enc\$ / READ_NOTE.html\$	T1486	10
100003	Conexión a puerto ICS	win.eventdata.destinationPort · 502/102/5900	T0822	9
100004	DNS a dominio Tor (.onion)	win.eventdata.queryName · .onion\$	T1090.003	8

Tabla 2. Grupo 1 (archivo BlackNet): reglas de detección desplegadas

Reglas Grupo 1:

```

<group name="local,">

  <rule id="100001" level="9">
    <if_group>sysmon_event_11</if_group>
    <regex>.AppData.Local.Temp._MEI.*.python313\.dll$</regex>
    <description>BlackNet-00 Ransomware - artefacto PyInstaller (python313.dll) creado en
    TEMP.</description>
    <mitre><id>T1059.006</id></mitre>
    <group>windows,ransomware,blacknet,</group>
  </rule>

  <rule id="100002" level="10">
    <if_group>sysmon_event_11</if_group>
    <regex>\.enc$|READ_NOTE\.html$</regex>
    <description>BlackNet-00 Ransomware - fichero cifrado (.enc) o nota de rescate
    (READ_NOTE.html) creado.</description>
    <mitre><id>T1486</id></mitre>
    <group>windows,ransomware,blacknet,</group>
  </rule>

  <rule id="100003" level="9">
    <if_group>sysmon_event3</if_group>
    <field name="win.eventdata.destinationPort">502|102|5900</field>
    <description>TRK25 SCADA - conexion a puerto de sistema de control industrial (Modbus 502,
    S7 102, VNC 5900).</description>
    <mitre><id>T0822</id></mitre>
    <group>windows,ics_scada,trk25,</group>
  </rule>

  <rule id="100004" level="8">
    <if_group>sysmon_event_22</if_group>
    <field name="win.eventdata.queryName">\.onion$</field>
    <description>BlackNet-00 Ransomware - consulta DNS a dominio Tor (.onion), indicio de
    C2.</description>
    <mitre><id>T1090.003</id></mitre>
    <group>windows,ransomware,blacknet,c2,</group>
  </rule>

</group>

```

3.2.3 Archivo ZPENTEST ALLIANCE (ZPENTEST ALLIANCE, RubinGroup/RubinView)

Posterior al análisis del grupo RaaS, se prosiguió con el foco central de este apartado, es decir, grupos hacktivistas rusos. Para ello se buscó analizar el ecosistema prorruso Z-Pentest Alliance, formado por una gran variedad de grupos, siendo los más

relevantes: NoName057(16), QuietSec, inteid, RubinGroup y ShadowClawz 404, entre otros (relación visible en las figuras del Anexo IV).

Dentro de este grupo, además de encontrar Dark Stresser (2026), plataforma DDoS perteneciente a QuietSec, se encuentra el framework ofensivo web RubinView, atribuido a RubinGroup. A diferencia del anterior grupo, estas reglas operan sobre los logs de servidor web, heredando de la regla base de acceso web de Wazuh (*if_sid 31100*) y empleando la URL y el código de respuesta HTTP.

-Regla 100005 y 100006: RubinView prueba miles de rutas (fuerza bruta de directorios), generando muchas respuestas 404. La 100005 marca cada 404 a una ruta sensible (nivel 5); la 100006 se dispara al acumularse 20 desde la misma IP en 60 s.

-Regla 100007: detecta payloads de explotación web en la URL: LFI (*../../../../etc/passwd, php://*), XXE (*<!ENTITY*), XSS (*%3Cscript, onerror=*) y SSRF (*?url=http://*).

-Regla 100008 y 100009: la 100008 marca respuestas 403 (bloqueo por WAF); la 100009 se dispara al acumularse 10 desde la misma IP en 60s, patrón de tanteo/evasión de WAF.

Regla	Detecta	Campo / patrón	MITRE	Nivel
100005	Ruta sensible con 404 (base)	<i>if_sid 31100 · id 404 · url rutas</i>	—	5
100006	Ráfaga de 404 (fuerza bruta dir.)	<i>if_matched_sid 100005 · 20 en 60s · misma IP</i>	T1595.003	10
100007	Payload LFI / XXE / XSS / SSRF en URL	<i>url · ../../etc/passwd, php://, %3Cscript ...</i>	T1190	9
100008	Respuesta 403 (base, tanteo WAF)	<i>if_sid 31100 · id 403</i>	—	5
100009	Ráfaga de 403 (evasión WAF)	<i>if_matched_sid 100008 · 10 en 60s · misma IP</i>	T1190	10

Tabla 3. Grupo 2 (archivo ZPENTEST): reglas de detección desplegadas

Reglas Grupo 2:

```

<group name="local,">

  <rule id="100005" level="5">
    <if_sid>31100</if_sid>
    <id>^404</id>
    <url>/.env|.git|wp-admin/|xmlrpc.php/administrator/</url>
    <description>Petición a ruta sospechosa (candidato a escaneo con RubinView).</description>
    <group>web,accesslog,rubinview,</group>
  </rule>

  <rule id="100006" level="10" frequency="20" timeframe="60">
    <if_matched_sid>100005</if_matched_sid>
    <same_source_ip />
    <description>Multiples rutas sospechosas desde la misma IP - escaneo/fuerza bruta de directorios (RubinView).</description>
    <mitre><id>T1595.003</id></mitre>
    <group>web,accesslog,rubinview,</group>
  </rule>

  <rule id="100007" level="9">
    <if_sid>31100</if_sid>
    <url>../../etc/passwd|php://filter|php://input|&lt;!ENTITY|%3Cscript|alert%28|onerror=|javascript:|?url=http://</url>
    <description>Intento de explotacion de aplicacion web (LFI, XXE, XSS, SSRF) con RubinView.</description>
    <mitre><id>T1190</id></mitre>
    <group>web,accesslog,rubinview,</group>
  </rule>

  <rule id="100008" level="5">
    <if_sid>31100</if_sid>
    <id>^403</id>
    <description>Petición con código 403 (candidato a evasión de WAF con RubinView).</description>
    <group>web,accesslog,rubinview,</group>
  </rule>

  <rule id="100009" level="10" frequency="10" timeframe="60">
    <if_matched_sid>100008</if_matched_sid>
    <same_source_ip />
    <description>Multiples 403 desde la misma IP - posible evasión de WAF (RubinView).</description>
    <mitre><id>T1190</id></mitre>
    <group>web,accesslog,rubinview,</group>
  </rule>

</group>

```

3.2.4 Archivo APK (AvangardSec, pol4rity, KIDS) / UAC-0252.

Esta agrupación forma parte también de Z-Pentest Alliance (relación con inteid y QuietSec, visible en Anexo V), pero se ha decidido analizar por separado debido a ser una subagrupación de tres canales que presentan una relación más estrecha, y debido a que se pudieron observar algunos TTPs diferentes a los del resto de grupos. Como se observa en la siguiente imagen, este grupo también tiene presencia contra el sector transporte español, liderando la Operación Bloodborne contra España/Alemania (sector logístico afectado).

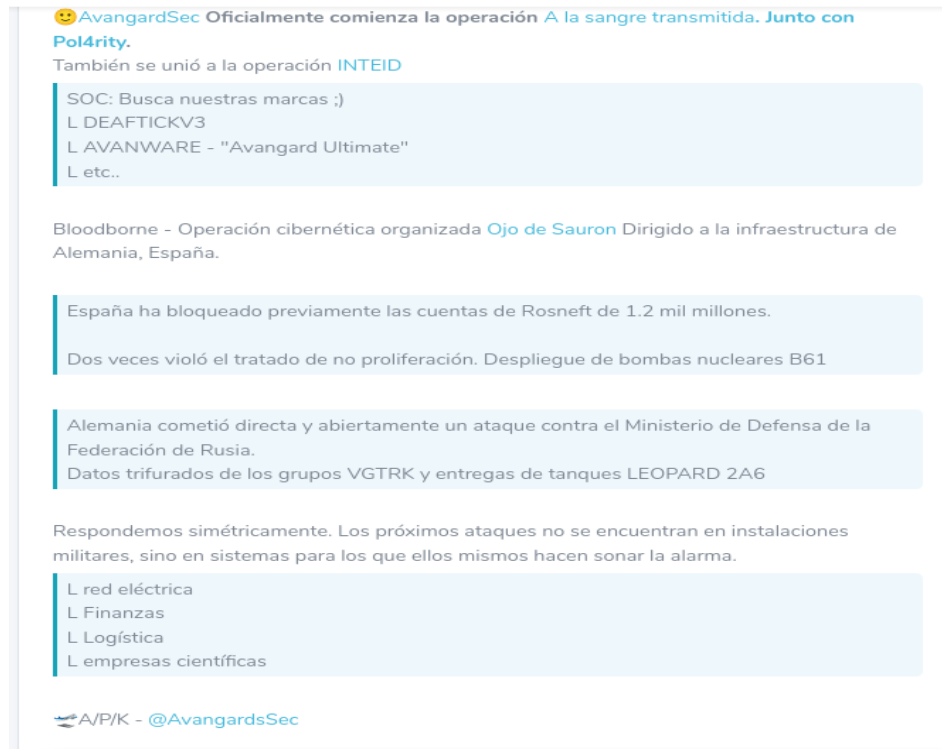


Fig. 7. Vía Telegram. AvangardSec

Esta agrupación fue rastreada por el CERT-UA como UAC-0252. En este caso, las reglas operan sobre endpoints Windows monitorizados por Sysmon.

-Regla 100010: el malware se enmascara ejecutando binarios con nombres legítimos (*svchost.exe*, *EdgeUpdate.exe*) desde rutas de usuario inusuales (Temp, caché de Edge). La regla detecta esa ejecución (EventID 1).

-Regla 100011: detecta comandos de evasión de defensas: exclusión en Defender (*Add-MpPreference -ExclusionPath*) u ocultación de ficheros (*attrib +h +s*), EventID 1. (Regla depurada a *type="pcre2"*.)

-Regla 100012: detecta persistencia mediante clave Run del registro (*WindowsUpdateService*, *MicrosoftEdgeUpdateTask*), EventID 13.

-Regla 100013: detecta consultas DNS (EventID 22) a los dominios de C2 y descarga de la campaña (*nfkavn.bond*, *salat.ru*, etc.).

Regla	Detecta	Campo / patrón	MITRE	Nivel
100010	Binario enmascarado en ruta de usuario	win.eventdata.image · Temp svchost.exe ...	T1036.005	9
100011	Evasión Defender / ocultación (attrib)	win.eventdata.commandLine (pcr2) · Add-MpPreference / attrib +h +s	T1562.001	9
100012	Persistencia clave Run	win.eventdata.targetObject · Run WindowsUpdateService	T1547.001	9
100013	DNS a dominio C2	win.eventdata.queryName · nfkavn.bond ...	T1105	8

Tabla 4. Grupo 3 (archivo APK): reglas de detección desplegadas

Reglas Grupo 3:

```

<group name="local,">
  <rule id="100010" level="9">
    <if_group>sysmon_event1</if_group>
    <field
name="win.eventdata.image">.AppData.Local.Temp.svchost\..exe$|.AppData.Roaming.Microsoft.Edge.C
ache.EdgeUpdate\..exe$|.AppData.Roaming.Microsoft.Edge.Cache.edge_updater\..exe$</field>
    <description>UAC-0252 - proceso enmascarado ejecutado desde ruta de usuario.</description>
    <mitre><id>T1036.005</id></mitre>
    <group>windows,attack,uac0252,masquerading,</group>
  </rule>

  <rule id="100011" level="9">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcr2">(?!)(Add-MpPreference\s+-
ExclusionPath|attrib\s+\h\s+\s)</field>
    <description>UAC-0252 - comandos de evasion de defensas u ocultacion de
ficheros.</description>
    <mitre><id>T1562.001</id></mitre>
    <group>windows,attack,uac0252,defense_evasion,</group>
  </rule>

  <rule id="100012" level="9">
    <if_group>sysmon_event_13</if_group>
    <field
name="win.eventdata.targetObject">HKCU.Software.Microsoft.Windows.CurrentVersion.Run.WindowsUp
dateService$|HKCU.Software.Microsoft.Windows.CurrentVersion.Run.MicrosoftEdgeUpdateTask$</fiel
d>
    <description>UAC-0252 - persistencia mediante clave de registro Run.</description>
    <mitre><id>T1547.001</id></mitre>
    <group>windows,attack,uac0252,persistence,</group>
  </rule>

  <rule id="100013" level="8">
    <if_group>sysmon_event_22</if_group>
    <field
name="win.eventdata.queryName">nfkavn\.bond$|salat\.cn$|salator\.es$|salator\.ru$|websalat\.to
p$|wrat\.in$|mk-gov-ua\.github\.io$|governmentncr\.github\.io$|security\.digital-
ua\.digital$|ua-gov\.info$</field>
    <description>UAC-0252 - consulta DNS a dominio de C2 o descarga de payload.</description>
    <mitre><id>T1105</id></mitre>
    <group>windows,attack,uac0252,dns,</group>
  </rule>
</group>

```

4. Arquitectura CTI: Scrapers + MISP + Wazuh + Telegram

4.1 Contexto previo sobre la infraestructura

4.1.1 Evolución de los SOC y la Inteligencia de Ciberamenazas (CTI)

- **Histórico:** hasta hace unos años, la ciberdefensa se basaba en Centros de Operaciones de Seguridad (SOC) de naturaleza puramente reactiva, centrados en el monitoreo de eventos internos mediante plataformas SIEM y respondiendo ante amenazas una vez materializadas.
- **Ineficacia del modelo:** el aumento de complejidad de los ciberataques ha evidenciado la necesidad de un enfoque más proactivo, enfocado al CTI.
- **Objetivo:** anticiparse a los incidentes mediante la recolección de Indicadores de Compromiso (IoCs), inteligencia de fuentes abiertas (OSINT), Dark Web y el estudio de Tácticas, Técnicas y Procedimientos (TTPs) de los actores de amenazas.
- **Estandarización:** plataformas como MISP se han erigido como el estándar para la consolidación de esta inteligencia.

4.1.2 El desafío de la Fatiga de Alertas

- **Saturación del servicio:** logs, feeds, eventos... los SIEMs acaban con volúmenes inabarcables de ruido y datos innecesarios, impactando negativamente tanto en el rendimiento de la plataforma como en la eficiencia del SOC.
- **Aumento de tiempo de respuesta:** al carecer de un sistema de filtrado previo, los analistas invierten la mayor parte de su tiempo en el triaje manual de falsos positivos.

4.1.3 Soluciones aportadas

- **Filtrado en origen:** se ha implementado un sistema de filtrado previo basado en expresiones regulares (RegEx) y listados dinámicos de activos (ficheros de texto)

- Pre-análisis: el filtrado de inteligencia se realiza en los scripts de recolección de datos, previa a la ingesta de información en las plataformas.
- Objetivo: alimentar al SIEM exclusivamente con alertas contextualizadas (enfocadas en el sector logístico español) y verificadas, reduciendo el ruido y alertando casi en tiempo real vía Telegram.
- Orquestación: las diferentes plataformas se comunican, están completamente integradas y sus procesos definidos en el tiempo

4.2 Elección de plataformas y justificación

El diseño se ha regido por criterios de eficiencia, bajo consumo de recursos y agilidad operativa.

4.2.1 Plataforma CTI: MISP frente a OpenCTI

- Eficiencia de recursos: OpenCTI (basado en microservicios como Elasticsearch, RabbitMQ y Redis) requiere de mayores recursos de hardware y gestión. MISP es ligero y adaptable a entornos virtualizados.
- Taxonomía: MISP permite un etiquetado (Tagging) granular (Sector:Logistica, Country:ES), el cual es imprescindible para el correcto filtrado posterior.
- Interoperabilidad: la librería PyMISP permite gestionar de forma eficiente los scripts en Python e inyectar y deduplicar eventos de forma eficaz y eficiente.

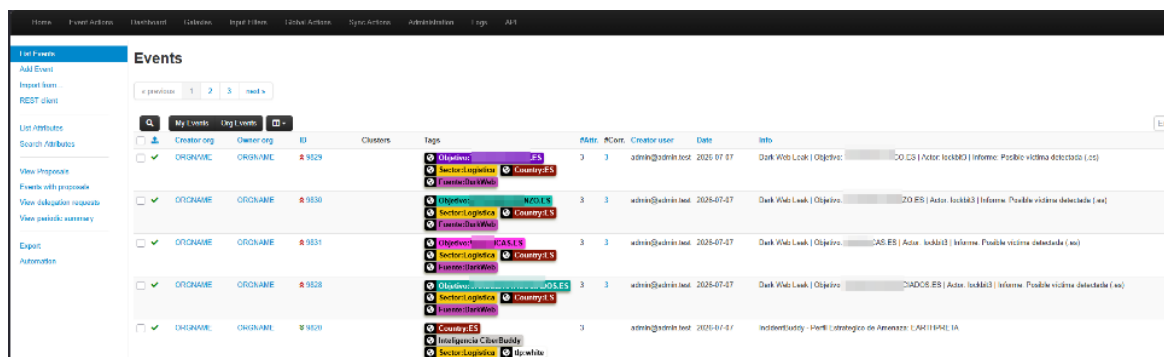


Fig. 8. Dashboard de la plataforma de inteligencia MISP

4.2.2 Motor Analítico: Wazuh frente al Stack ELK

- SIEM nativo: Wazuh permite ingestar directamente archivos JSON frente a la complejidad de mantener un Logstash en un ecosistema ELK.

- Integración con otras plataformas: el uso del módulo “integration” permite invocar scripts (como el envío de alertas a Telegram) de forma directa e inmediata, sin requerir herramientas de terceros (ej. ElastAlert).
- Mantenimiento eficiente: mediante el uso de la herramienta nativa “logrotate”, se delega el mantenimiento de la retención de datos al sistema operativo optimizando el espacio en disco y mejora de la gestión de la memoria RAM.

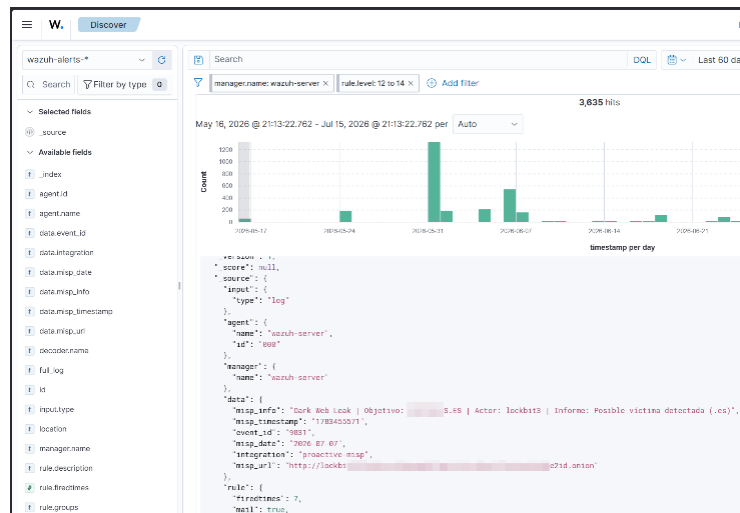


Fig. 9. Dashboard del SIEM Wazuh

4.2.3 Plataforma de mensajería para alertas - Telegram

- Madurez y simplicidad: la creación de un bot en Telegram permite la recepción directa de peticiones POST (Webhooks) sin requerir el despliegue de pasarelas intermedias, sistemas de autenticación tipo OAuth2 ni licenciamiento.
- Estructuración nativa: Telegram soporta de forma nativa el parseo de etiquetas HTML. Esta característica es fundamental para que el script integrador pueda traducir el JSON procedente del SIEM en una alerta estructurada (títulos, separadores, enlaces, etc.) y visualmente amigable.
- Alerta en tiempo real: la plataforma, al disponer de clientes ligeros y sincronizados tanto en entornos de escritorio como en dispositivos móviles con notificaciones en tiempo real, garantiza que el analista reciba la alerta crítica de forma instantánea, minimizando el tiempo de respuesta ante incidentes.
- Segregación y seguridad operativa: la plataforma permite la creación de canales privados dedicados, donde las comunicaciones viajan cifradas en tránsito

(HTTPS/TLS). Esto asegura que únicamente el bot y los operadores autorizados tengan acceso a la inteligencia.

4.3 Fase de Ingesta: scrapers y fuentes de inteligencia

Se han desarrollado nueve módulos en Python (en adelante scrapers) para consultar fuentes, buscar patrones, extraer el dato y etiquetar los eventos.

4.3.1 Características comunes

- Listados dinámicos: las búsquedas se alimentan de ficheros de texto plano lo que optimiza la actualización futura de dichos listados, en lugar de cambiar cada listado si hubiera estado hardcodeado en código.
- Etiquetado (tagging): cada evento se marca con una etiqueta y otros atributos para posteriormente facilitar su búsqueda y contextualizar el evento.
- Seguridad operacional (OPSEC): Uso de la librería `dotenv` para cargar credenciales de un archivo oculto (`/opt/.secrets.env`) que contiene datos sensibles (APIs, tokens, IDs, etc.) con permisos restrictivos.
- Comprobación de eventos duplicados: se implementa la función “`es_duplicado`” en todos los scrapers para consultar a MISP previa a la ingesta del evento y evitar así indicadores o eventos repetidos.
- Control de flujo: implementación de retardos (`time.sleep`) y límites de espera (`timeout`) para evitar bloqueos por límite de consultas en las diferentes APIs.

4.3.2 Listado de scrapers

a) Monitorización de Subdominios (`ingestor_cert.py`):

- Consulta el registro `crt.sh`.
- Usa `tlextract` para dividir el FQDN y analizar el subdominio
- Valida el IOC mediante consulta pasiva (GET) a la API de VirusTotal.



Fig. 10. Alerta en Telegram (crt.sh)

b) Dark Web Tor/Onion (ingestor_onion.py):

- Opera a través de proxy SOCKS5 local.
- Extrae dominios .es expuestos en texto plano, aunque no figuren en los diccionarios base. Determinados actores publican los dominios en su página principal (ej. LockBit 3.0)

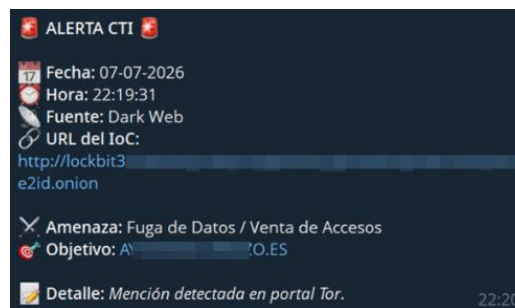


Fig. 11. Alerta en Telegram (red TOR)

c) Informes de campañas y ciberincidentes (ingestor_otx.py):

- Consume informes (pulses) de la plataforma AlienVault.
- Soluciona inconsistencias de nomenclatura de actores mediante búsquedas cruzadas.
- Extrae y preserva los Tags originales del creador del informe.

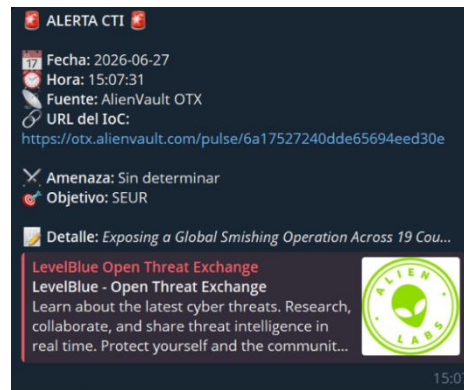


Fig. 12. Alerta en Telegram (OTX)

d) Shodan (ingestor_shodan.py):

- Identifica puertos críticos expuestos en la organización, así como vulnerabilidades (CVEs) asociadas a dichos puertos.
- En este caso, se ha usado una API de pago de la plataforma la cual, entre otras características, permite extraer los CVEs asociados a cada puerto analizado.
- Gestión WAF: si se reciben bloqueos (errores 403 y 429) por parte de escudos anti-bot, inyecta el evento para evitar pérdida de información (falso negativo)

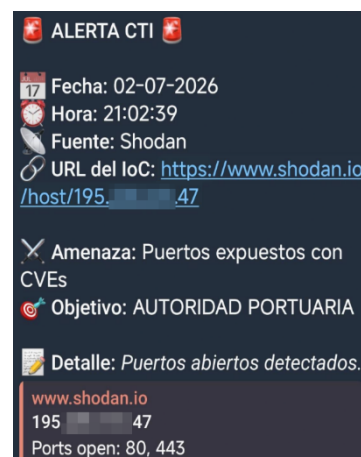


Fig. 13. Alerta en Telegram (Shodan)

e) Exposición de información en repositorios públicos (ingestor_paste.py):

- Monitoriza la aparición de los nombres de las empresas indicadas en el fichero empresas.txt en diferentes sitios paste.
- Al carecer de acceso a la API oficial, utiliza dorks de búsqueda mediante el motor DuckDuckGo por ser menos restrictivo que otros motores como Google.
- Utiliza marcas de tiempo para descartar bases de datos antiguas.



Fig. 14. Alerta en Telegram (paste)

f) Alertas de Ransomware (ingestor_ransomware.py):

- Utiliza la API de la plataforma ransomware[.]live, enfocada en grupos ransomware.



Fig. 15. Alerta en Telegram (ransomware)

g) Fuentes OSINT (ingestor_osint.py):

- Parseo de plataformas y canales RSS para extracción de noticias de actualidad relacionadas con el sector logístico.

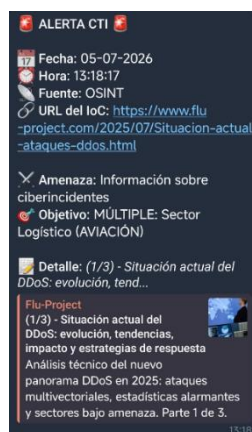


Fig. 16. Alerta en Telegram (osint)

h) Inteligencia Geopolítica (ingestor_eurepoc.py):

- Analiza un fichero local .xlsx descargado previamente de la plataforma Eurepoc
La idea original era usar la API, la cual se solicitó de manera formal pero no se pudo obtener debido a que no otorgaban acceso a particulares como puede apreciarse en la imagen inferior:

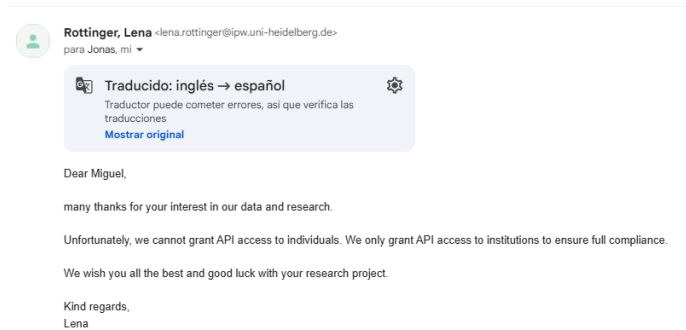


Fig. 17. Mail de respuesta de la plataforma EuRepoC

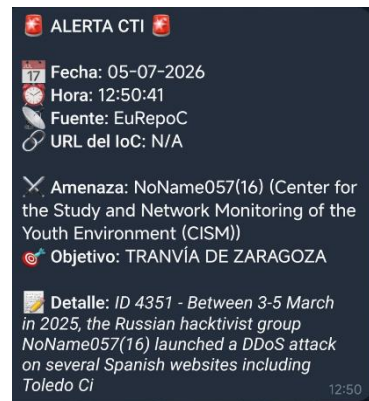


Fig. 18. Alerta en Telegram (EuRepoC)

i) Perfilado Estratégico (ingestor_incidentbuddy.py):

- Extrae Tácticas, Técnicas y Procedimientos (TTPs) de la plataforma de inteligencia IncidentBuddy conforme al framework MITRE ATT&CK.

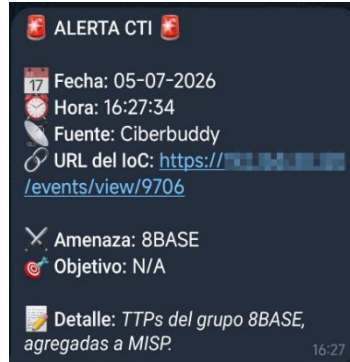


Fig. 19. Alerta en Telegram (CiberBuddy)

4.4 Orquestación y Mantenimiento

4.4.1 Tareas programadas (Cronjobs)

a) Ejecución de scrapers:

- Ruta: `/etc/cron.d/misp_tareas` (MISP).
- Los scrapers se ejecutan en minutos escalonados para prevenir solapamiento y evitar alto consumo de recursos.
- Para evitar consumir las consultas de determinadas APIs (como Shodan), se restringen a una ejecución semanal.

b) Middleware y Gestión de Estado:

- Ruta: `/opt/misp_ingestor.sh` (Wazuh)
- Script desarrollado en bash ejecutado cada 90 minutos.
- Solicita a la API de MISP eventos con etiquetas Sector:Logistica y Country:ES que no tengan el tag Telegram-Enviado.
- Caché MD5 (`/opt/.misp_cache.txt`): Sistema local de hashing para descartar IDs previamente procesados.
- Exportación a `/var/ossec/logs/misp_alerts.json` y etiquetado en origen como notificado.

4.4.2 Ingesta en Wazuh

- Ruta: */var/ossec/etc/ossec.conf*: fichero de configuración principal de Wazuh donde se definen ubicaciones de logs, json, notificaciones, etc. Es un fichero crítico para el correcto funcionamiento del SIEM.
- Regla Crítica: disparo de la Regla Personalizada 200505 configurada en */var/ossec/etc/rules/local_rules.xml*.
- Nivel 14 de alerta: la asignación de alta criticidad es debido a que, al filtrar el dato en origen y eliminar parcialmente los falsos positivos y ruido, hay altas probabilidades de que el dato extraído sea crítico; por tanto, cualquier evento que alcanza el SIEM es una posible amenaza.

4.4.3 Notificación y Resiliencia

- Alertado en Telegram: La regla 200505 invoca el script */var/ossec/integrations/custom-telegram.sh*.
- Extracción, transformación y carga (ETL): utiliza herramientas para extraer y procesar datos estructurados (awk), para normalizar el JSON (jq), formatear un mensaje HTML estandarizado y realizar un POST vía Webhook (envío final de alerta a bot de Telegram).
- Uso de fichero oculto y restringido */opt/.secrets.env* donde se almacena el token y el chatID de Telegram, necesarios para el envío de alertas con dicha plataforma.
- Mantenimiento: el script denominado “*limpieza_misp.py*” elimina IoCs con más de 30 días de antigüedad, preservando solo el histórico mensual.
- Rotación de logs: para optimizar el almacenamiento, se emplea el demonio “logrotate” sobre el archivo de alertas. Comprime los logs con la posibilidad de consultarlos, por ejemplo, con el comando “zgrep”.

5. Agente de Generación Automática de Reglas de Detección mediante Inteligencia Artificial

Este capítulo recoge el diseño, desarrollo iterativo e integración con Wazuh SIEM de un agente basado en modelos de lenguaje para la traducción de inteligencia de amenazas en reglas de detección.

5.1 Introducción y motivación

El presente capítulo describe el diseño, el desarrollo iterativo, la validación y la puesta en producción de un agente software desarrollado en Python cuya finalidad es automatizar la generación de reglas de detección para el sistema SIEM Wazuh a partir de informes de inteligencia de ciberamenazas (Cyber Threat Intelligence, CTI). Este componente constituye la contribución individual de este autor dentro del trabajo conjunto, en el que los restantes integrantes del equipo se ocuparon del despliegue y la configuración de la infraestructura Wazuh y MISP, del desarrollo de los recopiladores automatizados de inteligencia y del análisis de los actores de amenaza.

La motivación del agente surge de una limitación operativa habitual en los Centros de Operaciones de Seguridad (SOC): la traducción de la inteligencia de amenazas en reglas de detección es un proceso manual, lento y dependiente de personal especializado. Cada vez que se publica un informe sobre una nueva familia de malware o una campaña de ataque, un analista debe leer el documento, identificar los indicadores de compromiso (IOC) y las tácticas, técnicas y procedimientos (TTP), y redactar manualmente las reglas en la sintaxis específica del SIEM. Este flujo introduce una latencia considerable entre la aparición de una amenaza y la capacidad de detectarla.

El agente propuesto aborda esta problemática empleando un modelo de lenguaje de gran escala (LLM) de la familia Gemini de Google como motor de comprensión y traducción. El sistema ingiere un informe en formato PDF o texto plano, lo analiza mediante varias llamadas estructuradas al modelo y produce reglas de detección en el formato XML nativo de Wazuh, listas para su revisión y despliegue. El diseño incorpora de forma deliberada un punto de control humano (human-in-the-loop) previo a cualquier despliegue, garantizando que ninguna regla generada automáticamente llegue al entorno de producción sin la validación de un analista.

5.1.1 Objetivos del componente

1. Automatizar la extracción de IOC y TTP a partir de informes CTI heterogéneos, reduciendo la dependencia de la lectura manual.
2. Generar reglas de detección sintácticamente correctas para Wazuh 4.x sin intervención manual en la redacción del XML.
3. Garantizar la trazabilidad y el control de versiones de las reglas, evitando duplicidades y colisiones de identificadores.
4. Integrar el despliegue de reglas con la API REST de Wazuh, eliminando los pasos manuales de transferencia y recarga.
5. Mantener un punto de aprobación humana que preserve el control del analista sobre el contenido desplegado.

5.2 Arquitectura del sistema

El agente se concibe como un componente cliente que se ejecuta en la estación de trabajo del analista y se comunica con dos servicios externos: la API del modelo de lenguaje Gemini, alojada en la infraestructura de Google, y la API REST del gestor de Wazuh (Wazuh Manager), desplegado en un servidor Ubuntu dentro de la red del laboratorio. Esta separación permite delegar el procesamiento intensivo de lenguaje natural a un servicio en la nube, mientras que la lógica de control, validación y persistencia reside localmente.

5.2.1 Componentes principales

Componente	Función
Módulo de ingesta	Lee los ficheros PDF o TXT del directorio de entrada y extrae su contenido textual mediante la librería pypdf.
Motor de análisis IA	Coordina dos llamadas secuenciales al modelo Gemini: análisis integral de la amenaza (clasificación del sistema operativo objetivo, explicación técnica y extracción de IOC, con salida estructurada mediante esquema) y generación del XML de reglas.
Gestor de identificadores	Mantiene el fichero rules_repo.json, que registra los identificadores de regla utilizados y los metadatos de cada análisis, evitando colisiones y duplicidades.
Módulo de validación	Aplica correcciones de sintaxis específicas de Wazuh 4.x, ejecuta un validador local (linter) que advierte de patrones que impedirían la activación de las reglas y presenta el resultado al analista para su aprobación o rechazo.
Cliente API Wazuh	Autentica contra la API REST, sube la regla aprobada, valida la configuración del gestor antes de reiniciarlo y verifica tras el reinicio que la regla ha quedado efectivamente activa.

Tabla 5. Componentes principales del agente

5.2.2 Infraestructura del laboratorio

El entorno de pruebas se compone de un gestor Wazuh en su versión 4.13.1 desplegado sobre Ubuntu Server, un agente Wazuh instalado en un equipo Linux que actúa como objetivo monitorizado, y la estación de trabajo del analista, desde la que se ejecuta el agente de generación de reglas. La comunicación con el gestor se realiza a través de su API REST, expuesta en el puerto 55000 mediante el protocolo HTTPS, y a través del canal de comunicación de agentes en el puerto 1514.

5.3 Flujo de procesamiento

El procesamiento de un informe sigue una secuencia determinista de fases, diseñada para maximizar la fiabilidad de la salida del modelo de lenguaje. La decisión de fragmentar el análisis en llamadas independientes, en lugar de solicitar toda la información en una única interacción, responde a una observación empírica recogida durante el desarrollo: los modelos de lenguaje producen resultados más consistentes cuando cada llamada tiene un objetivo único y acotado, especialmente al generar contenido estructurado como XML. En su versión final, el flujo se articula en dos llamadas: la clasificación del sistema operativo, que inicialmente constituía una fase independiente, se integró en la llamada de análisis gracias al uso de salida estructurada con esquema, reduciendo el consumo de cuota sin pérdida de fiabilidad (véase la sección 5.4.14).

5.3.1 Fase 1 — Análisis integral de la amenaza

La primera llamada solicita al modelo un análisis estructurado en formato JSON que incluye la clasificación del sistema operativo objetivo de la amenaza (Windows, Linux o genérico), una explicación técnica del comportamiento del malware, una regla en formato Sigma exportable a otros sistemas y la extracción de los indicadores de compromiso presentes en el informe (direcciones IP, dominios, hashes y rutas de fichero). La clasificación del sistema operativo condiciona los grupos de reglas y las fuentes de log empleadas en la fase siguiente, ya que la sintaxis y los decodificadores de Wazuh difieren sustancialmente entre plataformas: una amenaza dirigida a Windows generará reglas asociadas a los eventos de Sysmon, mientras que una amenaza Linux se vinculará a los grupos de auditoría del sistema o del servicio SSH. La estructura de la respuesta se garantiza mediante un esquema declarativo de salida, que asegura la presencia y el tipo de todos los campos y elimina la necesidad de un parseo defensivo.

5.3.2 Fase 2 — Generación de reglas Wazuh

La segunda llamada produce las reglas de detección en el formato XML nativo de Wazuh. Esta fase incorpora un conjunto de instrucciones detalladas en el prompt que restringen la salida del modelo a la sintaxis válida de Wazuh 4.x, previenen la generación de reglas excesivamente genéricas que producirían un volumen inasumible de falsos positivos y, en la versión final, incluyen ejemplos de los formatos reales de los registros

de cada fuente de log, con el fin de evitar que el modelo construya patrones sobre campos inexistentes (véase la sección 5.4.12).

5.3.3 Artefactos generados

Por cada informe aprobado, el agente produce dos ficheros complementarios en el directorio de revisión, identificados por el rango de identificadores de las reglas generadas.

El primero, con extensión `.xml`, contiene las reglas de detección en el formato nativo de Wazuh, listas para su despliegue en el gestor. Es el artefacto operativo que se sube al SIEM y que activa la detección.

El segundo, con extensión `.json`, almacena el análisis completo producido por el modelo: la explicación técnica del comportamiento de la amenaza, los indicadores de compromiso extraídos (direcciones IP, dominios, hashes y rutas de fichero), y una regla equivalente en formato Sigma, portable a otros sistemas SIEM. Este fichero cumple una función documental y de trazabilidad: permite al analista revisar el razonamiento que sustenta cada regla y reutilizar la inteligencia extraída en otras plataformas, sin depender exclusivamente de Wazuh.

Adicionalmente, el agente registra los metadatos de cada análisis en el fichero `rules_repo.json`, incluyendo el rango de identificadores utilizados, la fecha, el fichero de origen y su hash. Este registro garantiza la trazabilidad del proceso, mantiene la continuidad de la numeración de reglas entre ejecuciones y evita el reanálisis de documentos ya procesados.

5.4 Desarrollo iterativo: problemas encontrados y soluciones

El desarrollo del agente fue un proceso netamente iterativo. Partiendo de una primera versión funcional pero frágil, se identificaron y resolvieron de forma incremental numerosos problemas técnicos, muchos de ellos derivados de las particularidades del modelo de lenguaje y de la sintaxis estricta de Wazuh. Cada problema resuelto se incorporó al código como una corrección documentada. A continuación, se describen las dificultades más relevantes y la solución adoptada en cada caso, ya que reflejan el grueso del esfuerzo de ingeniería del componente.

5.4.1 Obsolescencia del SDK de Gemini

Problema: la primera versión empleaba la librería `google-generativeai`, que durante el desarrollo quedó marcada como obsoleta por el proveedor, con riesgo de dejar de recibir soporte.

Solución: se migró todo el código a la nueva librería `google-genai`, que ofrece una interfaz más coherente para la configuración de los parámetros de generación y el manejo de las respuestas del modelo. La migración obligó a reescribir la inicialización del cliente y las llamadas de generación.

5.4.2 Restricciones de sintaxis de Wazuh 4.x

Problema: el modelo de lenguaje generaba XML sintácticamente válido en términos genéricos, pero que el gestor Wazuh 4.13.1 rechazaba. En concreto, el gestor no admite la cabecera de declaración XML, no acepta el atributo de tipo `PCRE2` en las expresiones regulares y no soporta el modificador de insensibilidad a mayúsculas dentro del patrón.

Solución: estas restricciones se incorporaron de forma explícita en las instrucciones del prompt y se reforzaron con una fase posterior de limpieza del XML generado, que elimina los elementos no admitidos antes de presentar la regla al analista. Se ajustó asimismo la generación para que las reglas heredasen correctamente de reglas base mediante los elementos de agrupación apropiados, evitando reglas huérfanas sin regla padre.

5.4.3 Errores de escapado entre JSON y XML

Problema: una de las dificultades más persistentes fue la generación incorrecta de caracteres de escape cuando se solicitaba al modelo que produjese simultáneamente el análisis en JSON y las reglas en XML dentro de una misma respuesta. Los conflictos de escapado entre ambos formatos corrompían la salida y provocaban fallos de parseo.

Solución: se separó la generación de XML en una llamada independiente que devuelve texto plano, eliminando los conflictos de escapado. Esta decisión es, en parte, el origen de la división entre las fases de análisis y de generación descrita en la sección anterior.

5.4.4 Respuestas vacías del modelo

Problema: en determinadas circunstancias —por ejemplo, cuando los filtros de seguridad del modelo bloqueaban una respuesta— el modelo devolvía un valor nulo en lugar de texto, lo que provocaba una excepción no controlada que abortaba la ejecución.

Solución: se introdujo una comprobación explícita del valor devuelto, generando un mensaje de error descriptivo que informa al analista de la posible causa (bloqueo por filtros de seguridad) en lugar de interrumpir el programa de forma abrupta.

5.4.5 Indisponibilidad temporal del modelo (errores 503 y 429)

Problema: el servicio Gemini devuelve ocasionalmente errores de tipo 503 (servicio no disponible) o 429 (límite de peticiones excedido) durante periodos de alta demanda o al agotar la cuota diaria del nivel gratuito. En las primeras versiones, estos errores interrumpían el flujo de trabajo y obligaban a relanzar el análisis manualmente, perdiendo el progreso.

Solución: se implementó un mecanismo de reintento automático con retroceso exponencial, que reintenta la petición hasta cuatro veces con esperas crecientes de diez, veinte y cuarenta segundos. El sistema distingue entre errores transitorios, que se reintentan, y errores permanentes (como una clave de API inválida), que se propagan de inmediato sin reintentos para no enmascarar fallos de configuración.

5.4.6 Generación de reglas excesivamente genéricas

Problema: en las primeras pruebas se observó que el modelo tendía a generar expresiones regulares excesivamente amplias. Por ejemplo, ante un informe sobre malware de Windows, generaba patrones que coincidían con cualquier carga de biblioteca dinámica, con la apertura de cualquier documento ofimático o con la ejecución de cualquier proceso. Tales reglas, aunque sintácticamente correctas, resultarían inservibles en producción por el volumen masivo de falsos positivos que generarían, agravando precisamente el problema de fatiga de alertas que el proyecto pretende mitigar. Un caso especialmente ilustrativo fue la generación de reglas para consultas DNS cuyo patrón intentaba coincidir con extensiones de fichero, algo que carece de sentido en ese contexto.

Solución: se reforzó el prompt de la fase de generación con ejemplos explícitos de patrones prohibidos y patrones recomendados, instruyendo al modelo para que

combinase siempre el nombre de un proceso con un argumento sospechoso o con una ruta anómala, y para que adaptase el patrón al tipo de evento. El siguiente fragmento resume el contraste enseñado al modelo:

Incorrecto:	<code>.*\.dll\$</code>	(coincide con cualquier DLL)
Incorrecto:	<code>.*\.doc.*</code>	(coincide con cualquier documento)
Incorrecto:	<code>.*\.exe</code>	(coincide con cualquier proceso)
Correcto:	<code>cmd\.exe.*powershell.*-enc</code>	
Correcto:	<code>powershell.*DownloadString IEX.*Net\.WebClient</code>	
Correcto:	<code>\\AppData\\Roaming.*\.exe</code>	

Tras esta corrección, la calidad de las reglas mejoró de forma notable. Mientras que las primeras versiones producían un porcentaje elevado de reglas inutilizables, las versiones posteriores generaban reglas específicas y desplegables en la práctica totalidad de los casos.

5.4.7 Detección de informes duplicados

Problema: la primera versión identificaba los informes ya analizados únicamente por su nombre de fichero, de modo que un mismo documento renombrado se volvía a analizar, generando reglas duplicadas y consumiendo identificadores innecesariamente.

Solución: el agente calcula ahora el hash SHA-256 del contenido de cada fichero y lo almacena en el registro de reglas. De este modo, un documento previamente analizado se detecta como duplicado aunque haya sido renombrado, aportando robustez frente a errores humanos en la gestión de los ficheros de entrada.

5.4.8 Truncamiento excesivo de los informes

Problema: para controlar el consumo de tokens, la primera versión limitaba la lectura a los primeros 12.000 caracteres de cada informe. Este límite resultó demasiado restrictivo: en informes extensos como los publicados por los CERT nacionales, se perdían secciones completas de indicadores de compromiso y recomendaciones, degradando la calidad del análisis.

Solución: se elevó el límite a 30.000 caracteres tras comprobar que el modelo empleado dispone de una ventana de contexto muy amplia y que el coste por análisis

permanecía dentro de límites razonables. Este valor cubre informes de aproximadamente sesenta páginas de texto denso sin un consumo excesivo de la cuota diaria de la API.

5.4.9 Externalización de credenciales

Problema: las credenciales sensibles —la clave de la API de Gemini y las credenciales de la API de Wazuh— se gestionaban inicialmente como variables de entorno definidas manualmente en cada sesión, lo que resultaba propenso a errores y poco seguro de cara a la publicación del código.

Solución: la configuración sensible se externalizó a un fichero de variables de entorno (.env) cargado automáticamente al inicio mediante la librería python-dotenv. Dicho fichero se excluye explícitamente del control de versiones, conforme a las buenas prácticas de seguridad en el desarrollo de software, y se acompaña de una plantilla de ejemplo sin credenciales reales para facilitar el despliegue por parte de terceros.

5.4.10 Nomenclatura incorrecta de grupos de reglas

Problema: durante la validación en directo se detectó que algunas reglas generadas para Linux no llegaban a activarse pese a estar correctamente desplegadas. Al inspeccionar la carga de reglas en el gestor, se comprobó que Wazuh las descartaba con una advertencia de grupo no encontrado. El modelo asignaba a las reglas de auditoría el grupo "auditd" (el nombre del demonio del sistema), cuando el grupo que Wazuh reconoce internamente se denomina "audit". Una diferencia mínima de nomenclatura provocaba que reglas perfectamente formadas fuesen ignoradas de forma silenciosa.

Solución: se corrigió la instrucción del prompt para indicar el nombre de grupo correcto, y de forma adicional se incorporó una regla de normalización en la fase de limpieza del XML que sustituye automáticamente cualquier aparición del grupo erróneo por el correcto antes de guardar la regla. Esta doble salvaguarda —corrección en origen y normalización posterior— garantiza que ninguna regla se pierda por este motivo, con independencia de la respuesta del modelo. Este caso resultó especialmente ilustrativo de la importancia de validar el comportamiento real de las reglas en el gestor, y no únicamente su corrección sintáctica.

5.4.11 Indicadores neutralizados (defanged) en los patrones de detección

Problema: los informes CTI publican los indicadores de compromiso en forma neutralizada (defanged) para evitar activaciones accidentales por parte del lector: `hxxp://` en lugar de `http://`, o `dominio[.]com` en lugar de `dominio.com`. Durante la validación se detectó que el modelo copiaba ocasionalmente esta notación de forma literal en las expresiones regulares generadas. La regla resultante era sintácticamente válida y superficialmente convincente, pero no podía activarse jamás, ya que ningún registro real contiene la notación neutralizada.

Solución: se aplicó la misma doble salvaguarda empleada con la nomenclatura de grupos. Por una parte, se añadió al prompt la instrucción explícita de emplear siempre la forma real de los indicadores en los patrones; por otra, la fase de limpieza del XML restaura automáticamente (refang) cualquier resto de notación neutralizada antes de guardar la regla.

5.4.12 Alucinación de formatos de registro

Problema: se trata del fallo más sutil detectado durante la validación. Al generar reglas basadas en el subsistema de auditoría de Linux (auditd), el modelo construía expresiones regulares contra un formato de registro plausible pero inexistente: identificaba la llamada al sistema por su nombre (`syscall=execve`) cuando los registros reales la identifican por su número (`syscall=59`), e inventaba campos (`oldmode=`, `newmode=`) que no figuran en los registros de tipo SYSCALL. Las reglas resultantes eran sintácticamente correctas y semánticamente coherentes con el informe, pero completamente inoperantes. Este comportamiento evidencia una limitación estructural de los modelos de lenguaje aplicados a la ingeniería de detección: el modelo conoce qué comportamiento debe detectarse, pero no necesariamente cómo se manifiesta ese comportamiento en un registro real.

Solución: se incorporó al prompt una guía de formatos con líneas reales de registro de cada fuente (auditoría del sistema y servicio SSH), acompañada de reglas explícitas sobre los campos válidos, y se instruyó al modelo para que en las reglas de auditoría empleara los campos ya decodificados por Wazuh (`audit.exe`, `audit.command`) mediante el elemento `field`, en lugar de expresiones regulares contra el registro en bruto, que constituye además la práctica recomendada por el fabricante. En la primera ejecución

posterior a este cambio, las reglas de auditoría generadas pasaron de ser inoperantes a emplear correctamente los campos decodificados, confirmando la eficacia del enfoque.

5.4.13 Validación local previa a la aprobación

Las salvaguardas descritas en las secciones anteriores reducen los fallos en origen, pero no pueden garantizar su ausencia. Por ello se incorporó una última capa de defensa: un validador local (linter) que, sin consumir llamadas al modelo, inspecciona las reglas generadas inmediatamente antes del punto de aprobación humana y advierte de los patrones que impedirían su activación —nombres de llamada al sistema en lugar de números, campos inexistentes, restos de notación neutralizada o patrones que coinciden con cualquier evento—, así como de incoherencias entre la descripción y el comportamiento real de la regla, como descripciones que anuncian la detección de intentos repetidos en reglas que se activan con un único evento.

El validador no bloquea la aprobación: presenta los avisos al analista, que decide con información completa si aprueba, corrige o rechaza la regla. El sistema queda así protegido por tres capas complementarias —prevención en el prompt, detección local automatizada y decisión humana final—, una arquitectura que refuerza el planteamiento human-in-the-loop del componente.

5.4.14 Optimización del consumo de cuota

Problema: el nivel gratuito de la API de Gemini limita el número de llamadas diarias. Con el flujo original de tres llamadas por informe, la capacidad quedaba restringida a un número reducido de análisis al día, lo que penalizaba las sesiones de validación intensiva.

Solución: la clasificación del sistema operativo, que constituía una llamada independiente, se integró como un campo adicional de la llamada de análisis, cuya estructura se garantiza mediante un esquema declarativo de salida con valores enumerados. El flujo pasó de tres a dos llamadas por informe —un incremento del cincuenta por ciento en la capacidad diaria de análisis— sin pérdida de fiabilidad observable. La generación del XML se mantuvo deliberadamente como llamada separada, al persistir los conflictos de escapado descritos en la sección 5.4.3.

5.4.15 Nomenclatura de grupos y campos en el ecosistema Sysmon (Windows)

Problema: un fallo estructuralmente idéntico al descrito en el apartado 5.4.10 para el subsistema de auditoría de Linux se manifestó también en las reglas dirigidas a Windows, aunque con una manifestación más sutil. Por un lado, el ruleset oficial de Wazuh para Sysmon nombra sus grupos de forma inconsistente según el identificador del evento: los eventos 1 a 9 (creación de procesos, conexiones de red, carga de bibliotecas) se agrupan como “sysmon_eventN”, sin guion bajo, mientras que los eventos 10 a 26 (creación de ficheros, modificación del registro, consultas DNS) requieren “sysmon_event_N”, con guion bajo. El modelo generaba sistemáticamente el nombre sin guion bajo para ambos rangos, de modo que las reglas asociadas a los eventos más numerosos —y más relevantes para la detección de persistencia y exfiltración— cargaban en el gestor sin error alguno, pero no llegaban a activarse nunca, al referenciar un grupo padre inexistente. Por otro lado, el modelo empleaba en ocasiones los nombres de campo nativos del formato XML de Sysmon (Image, TargetObject, CommandLine, QueryName) en el elemento field, en lugar de los nombres expuestos por el decodificador de Wazuh, que siguen la convención win.eventdata.* (o win.system.* para metadatos del propio evento). Un caso ilustrativo es el campo “NewValue”, que en el XML nativo de Sysmon recoge el valor tras una modificación del registro, pero que el decodificador de Wazuh no reproduce bajo ese nombre: el campo equivalente es win.eventdata.details.

Solución: se aplicó la misma doble salvaguarda de los apartados 5.4.10 y 5.4.11 —corrección explícita en el prompt, con la regla exacta de cuándo añadir el guion bajo y la lista cerrada de campos válidos del decodificador, y una normalización determinista en la fase de limpieza del XML que corrige ambos patrones antes de guardar la regla, con independencia de la respuesta del modelo. Este caso, sin embargo, dejó una lección adicional: durante la primera corrección se incluyó win.system.eventID en la lista de campos disponibles como recurso informativo, sin advertir de que resultaba redundante en cualquier regla que ya emplease if_group para fijar el tipo de evento. El modelo comenzó a añadir sistemáticamente este campo junto a la expresión regular ya existente en la misma regla, lo que activó de nuevo la incompatibilidad entre los elementos field y regex —el gestor rechaza el fichero de reglas completo cuando ambos coexisten en una misma regla—, y provocó que una tanda de once reglas fallase casi en su totalidad. La corrección definitiva no consistió en relajar esa restricción, sino en retirar

win.system.eventID de la lista de campos recomendados y sustituirlo por una prohibición explícita con ejemplos contrastados. El episodio ilustra un riesgo propio del enfoque iterativo: una corrección mal calibrada puede reintroducir, por una vía distinta, un fallo que ya se consideraba resuelto, lo que refuerza la necesidad de validar cada cambio del prompt contra el manager real y no solo contra la intuición de que la instrucción añadida es, en sí misma, correcta.

5.4.16 Regeneración automática ante fallos críticos del validador

Problema: el validador local descrito en el apartado 5.4.13 informa al analista de los patrones que impedirían la activación de una regla, pero deja en sus manos la decisión de corregir el XML manualmente o rechazar la tanda y volver a lanzar el análisis completo, lo que consume una nueva llamada al modelo para la fase de análisis, no solo para la de generación del XML.

Solución: se incorporó una fase de regeneración automática y acotada entre la generación del XML y su presentación al analista. Si el validador detecta algún patrón de los clasificados como críticos —aquellos que, según la experiencia acumulada, provocan el rechazo del fichero de reglas completo por parte del gestor—, el agente solicita al modelo una nueva generación del XML, reforzando el prompt original con un recordatorio explícito de las restricciones incumplidas, sin repetir la fase de análisis ni consumir de nuevo los indicadores ya extraídos. El número de reintentos está acotado a uno, tanto para limitar el consumo de cuota como para evitar bucles improductivos ante un informe genuinamente difícil de traducir a reglas válidas. Cuando la regeneración no resuelve todos los fallos críticos, el XML se presenta igualmente al analista junto con los avisos pendientes, preservando en todo momento el punto de control humano. Esta fase no sustituye a las tres capas descritas en el apartado 5.4.13, sino que se sitúa entre la segunda y la tercera, reduciendo la fricción operativa sin renunciar a ninguna de las salvaguardas existentes.

5.4.17 Referencias huérfanas en reglas compuestas

Problema: la validación con informes que combinaban comportamientos de red y de sistema —concretamente un informe sobre el ransomware BlackNet-00 y el framework de ataque a infraestructuras industriales TRK25— reveló una clase de fallo distinta a las descritas hasta ahora. El modelo generaba correctamente reglas compuestas

de frecuencia, empleando el elemento `if_matched_group` para escalar la severidad ante múltiples eventos del mismo origen, tal como exige la sintaxis de Wazuh 4.x. Sin embargo, en dos de las tres reglas compuestas de una misma tanda, el nombre de grupo referenciado en `if_matched_group` no coincidía con el que la regla base había declarado en su propio elemento `group`: el modelo inventaba, para el enlace entre ambas reglas, un nombre semánticamente plausible que ninguna regla del fichero llegaba a producir realmente. A diferencia de los fallos de sintaxis analizados en apartados anteriores, este error no impide la carga del fichero de reglas ni genera ningún mensaje de advertencia por parte del gestor: la regla de escalada, simplemente, no encuentra nunca una coincidencia y no dispara jamás, lo que la convierte en un fallo silencioso de naturaleza semántica, no sintáctica.

Solución: se amplió el validador local para que, antes de examinar cada regla individualmente, recopile el conjunto de todos los nombres de grupo declarados en el fichero de reglas completo. A continuación, por cada regla que emplee `if_matched_group`, comprueba si el nombre referenciado pertenece a dicho conjunto, y en caso contrario emite un aviso. Este aviso se clasifica deliberadamente como no crítico, ya que el nombre referenciado podría corresponder legítimamente a un grupo nativo del ruleset de Wazuh no presente en el fichero generado por el agente; se opta por informar al analista en lugar de forzar una regeneración automática. Se reforzó asimismo el prompt con la instrucción explícita de que todo nombre empleado en `if_matched_group` debe aparecer literalmente en el elemento `group` de la regla base correspondiente, junto con la recomendación de preferir `if_matched_sid` —que referencia un identificador numérico exacto y no depende de la coincidencia de una cadena de texto— salvo que exista una razón concreta para agrupar varias reglas base bajo un mismo disparador de escalada.

5.4.18 Mejora progresiva del sistema

Conviene precisar la naturaleza de la mejora observada a lo largo del desarrollo, para evitar una interpretación inexacta. El modelo de lenguaje empleado no se reentrena ni aprende de las ejecuciones del agente: es un servicio externo de comportamiento fijo. Lo que mejora de forma acumulativa no es el modelo, sino el sistema que lo gobierna.

Cada problema detectado durante la automatización de reglas —un grupo mal nombrado, una expresión regular demasiado amplia, un error de escapado— se tradujo

en un refinamiento del prompt o en una nueva validación incorporada al agente. De este modo, la experiencia acumulada en cada iteración se consolida en el propio código y en las instrucciones que guían al modelo, elevando progresivamente la calidad de las reglas generadas. En la práctica, esto se traduce en que el agente, conforme se ha ido empleando con informes reales y diversos, produce reglas cada vez más precisas y desplegables, porque las instrucciones que recibe el modelo están cada vez mejor calibradas frente a los casos problemáticos observados.

Asimismo, el repositorio de reglas (`rules_repo.json`) actúa como una base de conocimiento acumulativa del sistema: registra cada amenaza procesada y las reglas derivadas, lo que sienta las bases para futuras mejoras, como la reutilización de patrones de detección ya validados o la detección de solapamientos entre reglas. El sistema, por tanto, mejora no por un aprendizaje automático del modelo, sino por el perfeccionamiento iterativo de la ingeniería que lo rodea, un enfoque más controlable y auditable, y por ello más adecuado para un entorno de seguridad.

5.5 Integración con la API REST de Wazuh

La fase final del flujo automatiza el despliegue de la regla aprobada, eliminando los pasos manuales de transferencia por SCP y recarga del servicio que caracterizaban el flujo inicial. El cliente se autentica contra la API REST del gestor mediante credenciales que devuelven un testigo JWT de validez limitada. Con dicho testigo, el agente sube el fichero XML al directorio de reglas personalizadas del gestor y solicita su reinicio para activar la nueva regla.

5.5.1 Configuración del usuario de la API

Durante la integración se constató que el gestor Wazuh dispone de varios sistemas de usuarios independientes —el del panel de control, el del Indexer y el de la API REST—, lo que inicialmente generó confusión a la hora de autenticarse. Se documentó el procedimiento para restablecer la contraseña del usuario de la API REST, almacenada en una base de datos interna, y se verificó la autenticación y los permisos de subida de reglas antes de automatizar el proceso en el agente. Este procedimiento se ha recogido como guía de instalación reproducible para que el sistema pueda desplegarse en otros entornos.

5.5.2 Flujo de despliegue automatizado

Una vez el analista aprueba una regla, el agente ejecuta de forma encadenada la autenticación, la subida del fichero XML, la validación de la configuración resultante y el reinicio del gestor, informando en pantalla del resultado de cada paso. La validación previa al reinicio, realizada a través del punto de validación de la propia API, evita el escenario más delicado del despliegue automatizado: reiniciar el gestor con una regla que éste no puede cargar y dejar el servicio inoperativo. Si la validación falla, el agente elimina automáticamente la regla recién subida (rollback) y aborta el proceso sin reiniciar. Tras un reinicio correcto, el agente consulta la API de forma periódica hasta confirmar que la regla ha quedado efectivamente cargada, cerrando el ciclo con la confirmación del identificador con el que el analista podrá verificar la detección en el panel de control. En caso de que la subida automática falle, el agente muestra los comandos manuales equivalentes como mecanismo de respaldo.

5.5.3 Rollback ante fallos de la subida y matices de diagnóstico

La validación del flujo de despliegue reveló que el rollback descrito en el apartado 5.5.2 debía cubrir no solo el fallo de la validación de configuración, sino también un rechazo del propio punto de subida del fichero: en determinadas circunstancias, el gestor acepta la petición de subida y escribe el fichero en el directorio de reglas antes de comunicar el error, de modo que un fallo en ese primer paso podía dejar un fichero de reglas defectuoso en disco sin que el agente lo detectase. El mecanismo de rollback se extendió para cubrir todos los caminos de fallo de la subida, no únicamente el de la validación posterior, eliminando el fichero del gestor en cualquier escenario en que la operación no se complete con éxito.

Adicionalmente, se observó que el punto de subida de la API REST devuelve en ocasiones un error de sintaxis XML aun cuando el fichero ya ha superado la validación local del agente, un comportamiento coincidente con incidencias conocidas y documentadas públicamente del propio proyecto Wazuh. Ante esta circunstancia, una primera versión del agente informaba al analista de que dicho error podía tratarse de una incidencia de la propia interfaz de programación, ajena al contenido de la regla. Sin embargo, la validación con el informe de BlackNet-00 y TRK25 evidenció que ese mismo error también puede producirse cuando el fichero contiene un fallo real ya detectado por el validador local en el paso previo de aprobación, por ejemplo, la coexistencia de los

elementos field y regex en una misma regla. Ofrecer sistemáticamente la explicación de “incidencia de la interfaz” en ambos casos corría el riesgo de restar importancia a un fallo genuino y ya diagnosticado. Se corrigió el mensaje para que sea condicional al historial de avisos críticos de esa misma tanda: si el validador no había encontrado ningún aviso crítico, se mantiene la explicación de posible incidencia de la interfaz, con instrucciones para verificarlo directamente en el gestor sin reiniciar el servicio; si sí los había encontrado, el agente remite explícitamente a esos avisos en lugar de sugerir que el fallo es ajeno a la regla generada.

5.6 Ampliación de la cobertura de monitorización

Durante la validación se identificó una dependencia fundamental del enfoque: una regla de detección, por correcta que sea, no se activará si el agente Wazuh no está recopilando los eventos o vigilando las rutas del sistema en las que se manifiesta el comportamiento malicioso. Es decir, la capacidad de detección no depende únicamente de la calidad de la regla, sino también de la configuración de monitorización del agente.

Para maximizar la probabilidad de que las reglas generadas se activen, se amplió la configuración de monitorización de integridad de ficheros (File Integrity Monitoring, FIM) del agente. La configuración inicial vigilaba únicamente un conjunto reducido de directorios. Se amplió para cubrir las rutas habitualmente empleadas por el malware de Linux para alojar binarios, establecer persistencia y almacenar artefactos, incluyendo los directorios de bibliotecas del sistema, los directorios de ejecutables y las rutas de tareas programadas. Se incorporaron asimismo bloques de configuración equivalentes para sistemas Windows, cubriendo rutas de usuario, directorios temporales y claves de registro asociadas a la persistencia.

Esta ampliación implica vigilar un volumen de ficheros superior al estrictamente necesario para una amenaza concreta. En un entorno de producción con numerosos agentes, ello podría tener un impacto en el rendimiento y en el número de eventos generados, por lo que requeriría un ajuste fino. No obstante, en el contexto de este trabajo —un laboratorio con un número reducido de agentes— se consideró una decisión aceptable y deliberada, que prioriza la cobertura de detección sobre la optimización de recursos, tras valorar el compromiso con el equipo docente. Para las rutas más extensas

se optó por una verificación periódica en lugar de en tiempo real, con el fin de no saturar el mecanismo de notificación de cambios del sistema operativo.

5.7 Validación y resultados

La validación del agente se realizó mediante el procesamiento de informes CTI reales, entre ellos una alerta del centro de respuesta a incidentes de Ecuador sobre la familia de malware Emotet, así como un informe público de Microsoft sobre el troyano XorDDoS, dirigido a sistemas Linux. Para cada informe se verificó que las reglas generadas fuesen sintácticamente válidas, que el gestor las aceptase sin errores y que efectivamente se activasen ante la simulación del comportamiento malicioso correspondiente.

Se confirmaron ciclos de detección completos en el panel de control de Wazuh para reglas dirigidas a Linux —concretamente la detección de la creación del script de persistencia que XorDDoS aloja en el directorio de tareas programadas por hora, así como la detección de fuerza bruta contra el servicio SSH—, validando que el flujo de extremo a extremo, desde la ingesta del informe hasta la activación de la regla en el gestor, funcionaba según lo previsto. La simulación del comportamiento malicioso se realizó de forma segura, reproduciendo los artefactos descritos en los informes (creación de ficheros en las rutas de IOC e intentos de autenticación fallidos) sin necesidad de ejecutar malware real, conforme a la metodología empleada por los equipos de ingeniería de detección.

La validación permitió asimismo contrastar de forma empírica el efecto de las salvaguardas incorporadas: una ejecución sobre el informe de XorDDoS previa a la guía de formatos produjo dos reglas de auditoría inoperantes por emplear campos inexistentes —detectadas por el validador local—, mientras que la ejecución posterior al cambio generó reglas basadas en los campos decodificados correctos. Este contraste entre ejecuciones constituye la evidencia más clara del valor de la ingeniería de prompt y de la validación automatizada descritas en la sección 5.4.

Un contraste análogo se obtuvo con un informe centrado en amenazas dirigidas a Windows —el ransomware BlackNet-00 y el framework de ataque a infraestructuras industriales TRK25—, que permitió validar de forma específica las salvaguardas descritas en el apartado 5. el fallo descrito en el apartado

4.15. Una primera tanda de once reglas generadas antes de dichas correcciones presentó una tasa de fallo elevada: nueve de las once reglas combinaban de forma indebida los elementos `field` y `regex` a causa de la redundancia del campo `win.system.eventID`, y dos reglas compuestas referenciaban grupos de escalada inexistentes, según el fallo descrito en el apartado 5.4.17. Tras aplicar las correcciones correspondientes, una segunda generación sobre el mismo informe redujo la incidencia a un único aviso no crítico, y el ciclo completo —generación, validación local, subida por la API REST, validación de la configuración del gestor, reinicio y confirmación de la regla activa— se completó sin intervención manual. Este segundo contraste, sumado al ya descrito para el subsistema de auditoría de Linux, confirma que el patrón de mejora del sistema no es un episodio aislado, sino una dinámica sostenida a lo largo de las distintas familias de amenazas y sistemas operativos con los que se ha validado el agente.

6. Limitaciones identificadas

Tras analizar la información necesaria para realizar el estado del arte y el marco teórico del trabajo, se observaron cuatro limitaciones principales:

La primera es el sesgo de notificación ya que la información sobre incidentes procede mayoritariamente de fuentes abiertas (OSINT) y de la publicación voluntaria por parte de los actores o las víctimas, de modo que un número indeterminado de incidentes, especialmente en el sector privado, no se hace público, por lo que se suele subestimar la magnitud real de la amenaza.

La segunda es la dificultad de atribución, intrínsecamente compleja y a menudo provisional, por lo que las atribuciones recogidas, aun apoyándose en fuentes de solvencia reconocida como CISA, NSA o Europol, deben interpretarse con cautela.

La tercera es el uso exclusivo de fuentes abiertas, pues el análisis y el sistema operan únicamente sobre inteligencia de difusión pública (TLP: CLEAR) y no se ha tenido acceso a información clasificada ni a la telemetría interna de los operadores afectados.

La cuarta limitación, de carácter metodológico y especialmente relevante para este trabajo, es la asimetría en la cobertura de las fuentes abiertas según el tipo de actor. La observación de incidentes de ransomware sobre el transporte español resulta relativamente sencilla y de alto nivel de detalle, gracias a la existencia de fuentes estructuradas y consultables mediante API, como ransomware.live, que publica las víctimas reclamadas por los propios grupos. Por el contrario, los ataques de actores estatales (APT) y de grupos hacktivistas dirigidos específicamente al sector transporte español son escasamente documentados en fuentes abiertas, debido a la complejidad de la atribución, a la frecuente clasificación de la información de inteligencia y a la reducida existencia de análisis OSINT centrados en la intersección concreta entre estos actores y el transporte nacional. En consecuencia, los casos de APT y hacktivismo recogidos en este trabajo son comparativamente menos numerosos y se apoyan en alertas institucionales de alto nivel, como las de CISA y la NSA, y en informes agregados de tendencias, como los de Radware, antes que en datos granulares por víctima, sin embargo, esta asimetría no refleja una menor actividad real de dichos actores, sino una menor visibilidad en el ecosistema de fuentes abiertas, y se aborda de forma explícita en el Índice

de Confianza de las fuentes que cierra este documento. También, existe una restricción operativa de recolección directamente relacionada debido a que no fue posible automatizar el seguimiento de los canales de Telegram en los que los grupos hacktivistas reivindican sus ataques, dado que saltaba el mensaje ERROR al intentar conseguir la API y el HASH, por lo que no se pudo llevar a cabo. Por lo tanto, las cifras de actividad reflejadas en el trabajo constituyen un número conservador del volumen real reivindicado por estos grupos.

Respecto a la infraestructura MISP-Wazuh-Telegram, se han podido vislumbrar cinco limitaciones de gran relevancia:

- Sistemas Anti-Bot y WAFs: diferentes soluciones de protección perimetral (como Cloudflare) bloqueaban de forma recurrentemente la librería requests de Python.
- Restricciones de APIs gratuitas: plataformas como Shodan, VirusTotal o crt.sh tienen cuotas muy limitadas de consultas (aún más acusado en las versiones demo o gratuitas), minimizando la efectividad de los scrapers o forzando a realizar peticiones más extendidas en el tiempo.
- Falta de acceso a APIs oficiales: en el caso de EuRepoC, la denegación de acceso a la API (restringida a instituciones) forzó la implementación de un parseo offline de archivos .xlsx. En el caso de los sitios paste, al carecer de la API de pago de Pastebin, se tuvo que recurrir a motores alternativos como DuckDuckGo, aplicando dorks para realizar búsquedas web.
- Inestabilidad de la Red Tor: Tanto los endpoints como los nodos intermedios de la red Tor, presentaban caídas frecuentes o timeouts, forzando a introducir en el código varios reintentos de acceso y buscar nodos alternativos.
- Limitación por codificación idiomática: debido a que la infraestructura utiliza un motor de búsqueda basado en ficheros de texto con codificación latina y expresiones regulares configuradas para este alfabeto, el sistema no está diseñado para detectar otro tipo de codificación (cirílico, árabe, lenguas o dialectos orientales, etc.), por lo que no detectaría inteligencia accionable
- Falta de homogeneización en nomenclaturas: Las diversas plataformas de inteligencia denominan de forma diferente a los actores de amenaza (ej. lockbit,

lockbit 3.0, lockbit3), lo que exigió aumentar el listado usando variaciones en las denominaciones cargando aún más el tamaño del fichero.

Por último, en lo referente al agente IA, más allá de la dependencia de la configuración de monitorización ya comentada, se identificaron dos limitaciones adicionales. En primer lugar, la calidad del análisis depende directamente de la riqueza del informe de entrada: informes pobres en indicadores técnicos concretos producen reglas de menor valor, lo que subraya la importancia del punto de control humano antes del despliegue. En segundo lugar, las reglas dirigidas a Windows requieren que el endpoint disponga de Sysmon instalado y configurado, un prerequisite de la monitorización que es independiente del agente generador. De forma análoga, las reglas basadas en el subsistema de auditoría de Linux requieren que el endpoint tenga cargadas las reglas de auditoría correspondientes (por ejemplo, la auditoría de la ejecución de procesos), sin las cuales el sistema no genera los eventos que la regla evalúa; por este motivo, las detecciones basadas en la monitorización de integridad de ficheros resultaron ser las más fiables del conjunto.

7. Líneas de trabajo futuro

El componente desarrollado deja abiertas varias líneas de mejora que enriquecerían su capacidad y su autonomía:

- Adquisición de APIs comerciales: sustituir los métodos de scraping utilizados y las búsquedas mediante dorks por la adición de licencias empresariales, minimizando así los posibles bloqueos por WAF o anti-bots.
- Soporte multi-codificación: implementar herramientas o desarrollar librerías que generen de forma automática otras codificaciones para los términos con codificación latina, ampliando la capacidad de detección de los scrapers
- Correlación con telemetría empresarial: posibilidad de cruzar los IoCs almacenados por esta infraestructura con los eventos de los agentes endpoint (Wazuh Agents) en la red corporativa y generar inteligencia altamente accionable.
- Despliegue en alta disponibilidad (HA): dimensionar las necesidades de la empresa o el cliente e implementar arquitecturas tipo clúster para soportar un volumen masivo de eventos y logs sin degradación del servicio.
- Generación de reglas YARA: incorporar una cuarta fase de análisis que genere reglas YARA a partir de los hashes y las cadenas características extraídas del informe, desplegándolas en el componente de respuesta activa de Wazuh. Esto complementaría la detección basada en logs con detección basada en el contenido de los ficheros.
- Actualización automática de la monitorización: que el propio agente, al detectar rutas de fichero entre los IOC extraídos, proponga o aplique automáticamente la ampliación de la configuración FIM del agente correspondiente, cerrando el ciclo entre la generación de la regla y la monitorización necesaria para que se active.
- Reutilización de la base de conocimiento: explotar el repositorio de reglas acumulado para detectar solapamientos entre reglas, reutilizar patrones de detección ya validados y sugerir mejoras sobre reglas existentes.
- Evaluación cuantitativa sistemática: realizar una evaluación de la precisión y la cobertura de las reglas generadas sobre un corpus amplio y diverso de informes,

midiendo tasas de falsos positivos y de detección efectiva frente a un conjunto de control.

- Validación semántica de los metadatos: extender el validador local para comprobar automáticamente que los identificadores de técnicas MITRE ATT&CK existen y se corresponden con el comportamiento detectado por cada regla, y que las reglas Sigma generadas son sintácticamente válidas conforme a su especificación.
- Soporte de fragmentación de informes muy extensos: para documentos que excedan la ventana de contexto, implementar un mecanismo de troceado inteligente que analice el informe por secciones y consolide los resultados.
- Ampliación de fuentes de entrada: admitir la ingesta directa desde formatos estructurados como STIX o desde la propia plataforma MISP, integrando el agente más estrechamente con el resto de la arquitectura del proyecto.

8. Consideraciones Éticas y Legales

- La inteligencia recolectada proviene exclusivamente de fuentes de acceso público. Los scrapers mencionados realizan recolección con métodos éticos y legales. No se recopila o almacena información alguna más allá del evento generado. De igual manera, no se han perpetrado intrusiones ni escaneos intrusivos en redes de terceros.
- El sistema orienta sus búsquedas a nombres comerciales y dominios. Se omite de forma deliberada el almacenamiento o distribución de Información de Identificación Personal (PII) y credenciales en texto claro.
- Las subrutinas de evasión de WAFs y sistemas anti-bot, así como retardos operacionales, evitan la posibilidad de colapsar o ralentizar las plataformas consultadas.

9. Conclusiones

El presente Trabajo de Fin de Máster pretende demostrar que el sector del transporte y la logística en España requiere una transición hacia modelos defensivos proactivos. Dada su criticidad operativa, la convergencia IT/OT y las amenazas en constante evolución de actores RaaS, APTs y hacktivistas, depender exclusivamente de sistemas reactivos resulta insuficiente. Para abordar este desafío y combatir la saturación de información que excede los recursos de los Centros de Operaciones de Seguridad (SOC), se ha diseñado, implementado y validado un ecosistema integral de Ciberinteligencia (CTI) automatizado.

En primer lugar, la arquitectura de ingesta de indicadores ha demostrado la eficacia de la eliminación parcial del ruido informativo en el propio origen. Mediante el desarrollo de módulos de recolección (*scrapers*), el uso de expresiones regulares y la resiliencia frente a medidas anti-bot, se ha logrado extraer inteligencia contextualizada tanto de fuentes abiertas y la Dark Web. La orquestación de estos datos entre MISP y Wazuh garantiza que se procesen amenazas con un alto grado de verificación, finalizando el proceso en un sistema de alertas inmediato y accionable a través de Telegram.

En segundo lugar, se ha desarrollado un agente basado en Modelos de Lenguaje de Gran Escala (LLMs). Este componente permite traducir de forma automatizada informes CTI heterogéneos en reglas XML nativas para Wazuh. Con este enfoque, se mejora de forma exponencial la capacidad de detección, complementándola con el muy necesario y fundamental criterio del analista, cuya labor cognitiva e interpretativa sigue siendo el núcleo insustituible del análisis de inteligencia.

Este modelo no solo reduce los tiempos técnicos de respuesta, sino que transforma datos crudos y dispersos en inteligencia predictiva, alineando la seguridad del sector con los estrictos requerimientos de la actual normativa europea (NIS2), por tanto, se podría yuxtaponer a cualquier sector empresarial o gubernamental.

En conclusión, la integración de un perfilado continuo de adversarios, un proceso automatizado de extracción de IoCs y la generación de reglas asistida por IA, genera un sistema unificado proactivo de inteligencia de ciberamenazas que, junto con los sistemas defensivos, forman un ecosistema muy sólido.

10. Bibliografía

- Agencia de Ciberseguridad de la Unión Europea (ENISA) (2025). *ENISA Threat Landscape 2025*. <https://www.enisa.europa.eu/sites/default/files/2025-11/ENISA%20Threat%20Landscape%202025.pdf>
- Agencia de Ciberseguridad de la Unión Europea (ENISA) (2023). *ENISA Threat Landscape 2023: Transport Sector* (informe sectorial). https://www.enisa.europa.eu/sites/default/files/all_files/03-cooperation-information-sharing-03-enisa-theocharidou.pdf
- Agencia de Ciberseguridad de la Unión Europea (ENISA) (2021). *Railway Cybersecurity: Good Practices in Cyber Risk Management*. <https://www.enisa.europa.eu/sites/default/files/publications/ENISA%20Report%20-%20Railway%20Cybersecurity%20-%20Good%20Practices%20in%20Cyber%20Risk%20Management.pdf>
- Agencia de Ciberseguridad de la Unión Europea (ENISA) (2019). *Port Cybersecurity: Good Practices for Cybersecurity in the Maritime Sector*. <https://www.enisa.europa.eu/publications/port-cybersecurity-good-practices-for-cybersecurity-in-the-maritime-sector>
- Agencia de Ciberseguridad de la Unión Europea (ENISA) (2016). *Securing Smart Airports*. <https://www.enisa.europa.eu/publications/securing-smart-airports>
- Bianco, D. J. (2013). *The Pyramid of Pain*. <https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- Caltagirone, S., Pendergast, A. y Betz, C. (2013). *The Diamond Model of Intrusion Analysis*. Center for Cyber Intelligence Analysis and Threat Research (CCIATR). <https://www.activeresponse.org/wp-content/uploads/2013/07/diamond.pdf>
- CERT-UA (2026). *Кібератаки UAC-0252 з використанням стілерів SHADOWSNIFF та SALATSTEALER (CERT-UA#20032)* [Ataques cibernéticos UAC-0252 que utilizan los programas espía SHADOWSNIFF y SALATSTEALER (CERT-UA#20032)]. <https://cert.gov.ua/article/6287707>

- Chiapetta, T. (2026). *BLACKNET-00 and the Rise of Zero-Skill Ransomware*. Cyber Defense Solutions, LLC. <https://prevent-ransomware.com/blog/blacknet-00-and-the-rise-of-zero-skill-ransomware>
- Cichocki, R., y Wójcik, P. (2025). *Cybersecurity in maritime transport systems: Threats, trends and countermeasures in the last decade*. TransNav, the International Journal on Marine Navigation and Safety of Sea Transportation, Vol. 19, No. 3, pp. 715-722. doi:10.12716/1001.19.03.03. https://www.transnav.eu/Article_Cybersecurity_in_Maritime_Transport_Cichocki,75,1553.html#
- CrowdStrike Falcon Sandbox (2026). *Análisis automatizado de la muestra blacknet-00.exe* [Informe de sandbox]. Hybrid Analysis. <https://hybrid-analysis.com/sample/10e41edc96baf6511a06832519823d0a1bf329fecde1d7d2ab9b2eda3a27a09>
- Cybersecurity and Infrastructure Security Agency (CISA) (2025). *Russian GRU Targeting Western Logistics Entities and Technology Companies (AA25-141A)*. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141a>
- Cybersecurity and Infrastructure Security Agency (CISA) (2020). *Insider Threat Mitigation Guide*. https://www.cisa.gov/sites/default/files/2022-11/Insider%20Threat%20Mitigation%20Guide_Final_508.pdf
- DeXpose (2026a). *Qilin ransomware targets Spanish logistics firm Avitrans*. <https://www.dexpose.io/qilin-ransomware-targets-spanish-logistics-firm-avitrans/>
- DeXpose (2026b). *Qilin targets Spanish logistics firm Operinter*. <https://www.dexpose.io/qilin-targets-spanish-logistics-firm-operinter/>
- DKS (2026). *Introducción al Cyber Threat Intelligence: Módulo 01, sesiones 01 y 02* [Diapositivas de PowerPoint]. Máster en Cyber Threat Intelligence, Digital Knowledge School.
- ESET (2025). *ESET APT Activity Report (abril 2025-septiembre 2025)*. <https://web-assets.esetstatic.com/wls/en/papers/threat-reports/eset-apt-activity-report-q2-2025-q3-2025.pdf>

- Europol (2025a). *Global operation targets NoName057(16) pro-Russian cybercrime network* [Nota de prensa]. <https://www.europol.europa.eu/media-press/newsroom/news/global-operation-targets-noname05716-pro-russian-cybercrime-network>
- Europol (2025b). *Internet Organised Crime Threat Assessment (IOCTA) 2025: Steal, Deal and Repeat – How Cybercriminals Trade and Exploit Your Data*. <https://www.europol.europa.eu/publication-events/main-reports/steal-deal-and-repeat-how-cybercriminals-trade-and-exploit-your-data>
- Group-IB (s.f.). *MuddyWater APT Group: Iranian Cyber Espionage Profile*. <https://www.group-ib.com/masked-actors/muddywater/>
- Habler, E., Bitton, R., y Shabtai, A. (2023). *Assessing Aircraft Security: A Comprehensive Survey and Methodology for Evaluation*. ACM Computing Surveys, 56*(4), art.96. <https://doi.org/10.1145/3610772>
- Hutchins, E. M., Cloppert, M. J., y Amin, R.M. (2011). *Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains (Cyber Kill Chain)*. Lockheed Martin. <https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Intel-Driven-Defense.pdf>
- IBM (2026). *X-Force Threat Intelligence Index 2026* [informe corporativo; acceso mediante formulario]. <https://www.ibm.com/es-es/reports/threat-intelligence>
- Instituto Nacional de Ciberseguridad (INCIBE) (2026). *Balance de Ciberseguridad 2025*. https://www.incibe.es/sites/default/files/2026-02/Balance%20de%20ciberseguridad%202025%20INCIBE/BalanceCiberseguridad2025_INCIBE.pdf
- Internet Assigned Numbers Authority (IANA) (2026). *Service Name and Transport Protocol Port Number Registry*. <https://www.iana.org/assignments/service-names-port-numbers>
- Microsoft Threat Intelligence (2024). *Peach Sandstorm deploys new custom Tickler malware in long-running intelligence gathering operations*. Microsoft Security Blog. <https://www.microsoft.com/en-us/security/blog/2024/08/28/peach->

[sandstorm-deploys-new-custom-tickler-malware-in-long-running-intelligence-gathering-operations/](#)

MITRE Corporation (s.f.). *MITRE ATT&CK* [base de conocimiento; matrices Enterprise e ICS; perfiles de grupos]. <https://attack.mitre.org/> (matriz Enterprise: <https://attack.mitre.org/matrices/enterprise/> ; matriz ICS: <https://attack.mitre.org/matrices/ics/> ; perfil de grupos: <https://attack.mitre.org/groups/>).

NTT DATA Cybersecurity (2026). *Tendencias CTI: Ciberinteligencia de Amenazas- Segundo semestre 2025* [informe corporativo; acceso mediante formulario]. <https://ar.nttdata.com/insights/reports/cyber-threat-intelligence-trends>

NTT DATA Cybersecurity (2025a). *CTI Trends-Primer semestre 2025 (H1 2025)* [informe corporativo; acceso mediante formulario]. <https://be.nttdata.com/insights/reports/cyber-threat-intelligence-trends-2025>

NTT DATA Cybersecurity (2025b). *Second Half 2024 Cyber Threat and Trends Report (CTI Trends)*. <https://mc-8afc6902-e56c-432c-8c3f-3991-cdn-endpoint.azureedge.net/-/media/project/emea/pt/files/pdfs/cti-tendencias-english.pdf>

OASIS Open (2021). *STIX Version 2.1 y TAXII Version 2.1 (OASIS Standards)*. STIX: <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html> y TAXII: <https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html>

Obsidian Corps (2026). *MISP vs OpenCTI: Choosing a threat intelligence platform*. <https://obsidiancorps.com/en/blog/2026/06/misp-vs-opencti>

Proofpoint (s.f). *¿Qué es la fatiga de alertas?* <https://www.proofpoint.com/es/threat-reference/alert-fatigue>

Puertos del Estado (2022). *II Plan de Igualdad de Trato y de Oportunidades 2022-2026*. <https://www.puertos.es/institucional/recursos-humanos/igualdad-de-genero>

Radware (2026). *2026 Global Threat Analysis Report*. <https://www.radware.com/threat-analysis-report/>

- SEC-1275-1 (2026). Кибератака на украинские госструктуры: фишинг под видом обновлений и угроза программ-вымогателей [Ciberataque contra agencias gubernamentales ucranianas: Phishing bajo la apariencia de actualizaciones y la amenaza de ransomware]. https://1275.ru/ioc/kiberataka-na-ukrainskie-gosstruktury-fishing-pod-vidom-obnovleniy-i-ugroza-programm-vymogateley_20706
- SOCRadar (2026). *Spain Threat Landscape Report 2025* [informe corporativo; acceso mediante formulario]. <https://socradar.io/resources/report/spain-threat-landscape-report-2025/>
- Unit 42-Palo Alto Networks (2026). Boggy Serpens Threat Assessment [perfil de MuddyWater]. <https://unit42.paloaltonetworks.com/boggy-serpens-threat-assessment/>
- Unit 42-Palo Alto Networks (2025). *Extortion and Ransomware Trends (January-March 2025)*. <https://unit42.paloaltonetworks.com/2025-ransomware-extortion-trends/>
- Villadsen, O., Larson, S., y Proofpoint Threat Research Team (2025). *Remote access, real cargo: cybercriminals targeting trucking and logistics*. Proofpoint. <https://www.proofpoint.com/us/blog/threat-insight/remote-access-real-cargo-cybercriminals-targeting-trucking-and-logistics>
- World Economic Forum (2025). *Global Cybersecurity Outlook 2025*. <https://www.weforum.org/publications/global-cybersecurity-outlook-2025/>

11. Otras fuentes consultadas

Plataformas y bases de datos:

Dark Stresser (2026). *Dark Stresser-DDoS Simulation* [Sitio web de servicio booter/stresser de QuietSec]. No se ofrece el link por OPSEC.

European Repository of Cyber Incidents (EuRepoC) (2026). *EuRepoC Database: Open-access database of cyber incidents*. <https://eurepoc.eu/database/>

MISP Project (2026). *PyMISP: Python library using the MISP Rest API* (Versión 2.5.34.1) [Software]. Github. <https://github.com/MISP/PyMISP>

Ransomware.live (2026). *Base de datos y API de víctimas de ransomware*. <https://www.ransomware.live/>

Telemetr.io (2026). *Telemetr.io Telegram Analytics*. [Plataforma de estadísticas de Telegram]. <https://telemetr.io/es>

TGStat (2026). *TGStat Telegram Channels Analytics*. [Plataforma de estadísticas de Telegram]. <https://tgstat.com/>

Prensa y medios especializados:

Cadena de Suministro (2026). *Ciberataque neutralizado en el puerto de Vigo*. https://www.cadenadesuministro.es/transporte-maritimo/ciberataque-neutralizado-en-puerto-vigo_1514958_102.html

Cybersecurity Dive (2025). *RTX confirms hack of passenger boarding software involved ransomware* [Collins Aerospace/MUSE]. <https://www.cybersecuritydive.com/news/rtx-hack-passenger-boarding-software-ransomware/761265/>

elDiario.es (2025). *Una caída de los servidores informáticos de Adif provoca retrasos en la alta velocidad con Madrid como origen o destino*. https://www.eldiario.es/economia/caida-servidores-informaticos-adif-provoca-retrasos-alta-velocidad-madrid-origen-destino_1_12577796.html

- El Mercantil (2025). *Aena amplía inversiones hasta 2026 para adelantar actuaciones en ciberseguridad.* <https://elmercantil.com/2025/07/01/aena-amplia-inversiones-hasta-2026-para-adelantar-actuaciones-en-ciberseguridad/>
- Galicia Press (2026). *Ciberataque bloquea el Puerto de Vigo durante toda la jornada.* <https://www.galiciapress.es/articulo/economia/2026-03-24/5821118-ciberataque-bloquea-puerto-vigo-durante-toda-jornada>
- Guardia Civil (2026). *Detenidos los cuatro principales integrantes del grupo hacktivista ‘Anonymous Fénix’ por ciberataques contra organismos públicos.* <https://web.guardiacivil.es/es/destacados/noticias/Detenidos-los-cuatro-principales-integrantes-del-grupo-hacktivista-Anonymous-Fenix-por-ciberataques-contra-organismos-publicos/>
- Help Net Security (2026). *Spanish police arrest suspected Anonymous members over DdoS attacks on government sites.* <https://www.helpnetsecurity.com/2026/02/23/spain-guardia-civil-arrests-anonymous-fenix-ddos-attacks/>
- Ministerio de Transportes y Movilidad Sostenible (2025). *El Gobierno autoriza una inversión adicional para impulsar proyectos clave en la red de aeropuertos de Aena.* https://www.transportes.gob.es/recursos_mfom/sala_prensa/250701_np_cm_inversion_adicional_2025-26_aena.pdf
- Tinku (2026). *Adif y la crisis de Rodalies: ¿ciberataque o fallo crítico en la infraestructura?* <https://tinku.es/adif-y-la-crisis-de-rodalies-ciberataque-o-fallo-critico-en-la-infraestructura/>

12. Legislación

Directiva (UE) 2022/2555 (2022). Directiva (UE) 2022/2555 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad en toda la Unión. *Diario Oficial de la Unión Europea*, L 333, 80-152. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj?locale=es>

Reglamento (UE) 2022/2554 (2022). Reglamento (UE) 2022/2554 del Parlamento Europeo y del Consejo de 14 de diciembre de 2022 sobre la resiliencia operativa digital del sector financiero. *Diario Oficial de la Unión Europea*, L 333, 1-79. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj?locale=es>

13. Anexos

13.1 Anexo I

Análisis PESTEL:

El sector transporte y la cadena de suministro (*Supply Chain*) se ha convertido en uno de los principales objetivos de los cibercriminales debido a su alta dependencia tecnológica, su criticidad temporal y el gran volumen de datos que maneja.

- Factor Político (P)

Geopolítica y Ataques de Estado (APTs): En un contexto de inestabilidad global (conflictos bélicos, tensiones comerciales), el transporte es un objetivo estratégico. Los ataques patrocinados por Estados buscan interrumpir el suministro de bienes esenciales (medicamentos, alimentos, energía) para desestabilizar naciones.

Protección de Infraestructuras Críticas: Los gobiernos están catalogando cada vez más a los grandes operadores logísticos y puertos.

- Factor Económico (E)

El impacto financiero de un ciberataque en este sector es inmediato y devastador.

Lucratividad del Ransomware: Los grupos de cibercrimen saben que el sector logístico opera con márgenes de tiempo muy ajustados por lo que cada minuto de inactividad genera pérdidas millonarias y paraliza la distribución, lo que aumenta drásticamente la probabilidad de que la empresa pague el rescate por desesperación.

Presupuesto asimétrico en ciberseguridad: Mientras que las grandes multinacionales invierten fuertemente en Centros de Operaciones de Seguridad (SOC), el tejido logístico español está compuesto mayoritariamente por pymes (transportistas locales, pequeños almacenes) que carecen de presupuesto para defensas robustas, convirtiéndose en el eslabón más débil de la cadena de suministro.

- Factor Social (S)

El factor humano sigue siendo el vector de entrada principal para los atacantes.

Ingeniería Social y Fatiga: Los empleados de logística, aduanas y atención al cliente manejan un volumen masivo de correos y albaranes diarios. Esto los hace altamente vulnerables a campañas de *Phishing* o *Spear-Phishing* que suplantan facturas, trackings de envíos o documentos aduaneros.

Falta de concienciación en la operativa de campo: Conductores, mozos de almacén y operarios a menudo utilizan dispositivos corporativos (PDAs, tablets) conectados a redes públicas o carecen de formación básica en ciberhigiene, facilitando infecciones por malware.

- **Factor Tecnológico (T)**

La transformación digital del sector ha ampliado masivamente la superficie de ataque.

Proliferación del IoT y OT: La automatización de almacenes, el uso de sensores de temperatura (cadena de frío), el seguimiento de flotas por GPS y la robótica introducen miles de dispositivos conectados que, a menudo, carecen de protocolos de seguridad integrados.

Interconexión de APIs (Riesgo de Terceros): Las plataformas logísticas modernas están interconectadas con clientes, proveedores y aduanas. Una vulnerabilidad en la API de un proveedor de software pequeño puede dar a los atacantes acceso directo a la red corporativa del operador logístico principal.

Sistemas Legacy: Muchas infraestructuras portuarias y ferroviarias aún dependen de sistemas de control industrial (SCADA/ICS) heredados y obsoletos que son difíciles de parchear y no fueron diseñados para estar conectados a Internet.

- **Factor Ecológico / Ambiental (E)**

Este factor presenta un impacto reducido

- Factor Legal (L)

La presión regulatoria sobre la ciberseguridad nunca ha sido tan alta.

Directiva NIS2 (UE): Esta nueva directiva europea obliga al sector logístico y de transporte a implementar medidas de ciberseguridad mucho más estrictas y a reportar incidentes graves en un plazo máximo de 24 horas. El incumplimiento conlleva multas millonarias y la posible inhabilitación de directivos.

Reglamento General de Protección de Datos (RGPD / LOPDGDD): Las empresas logísticas almacenan datos personales críticos (nombres, direcciones, teléfonos, rutinas de clientes). Las fugas de información (*Data Breaches*) derivadas de ciberataques exponen a las compañías a sanciones severas y demandas colectivas, además del daño reputacional.

13.2 Anexo II

Ejemplos de ataques hacktivistas de NoName057(16) al transporte español.

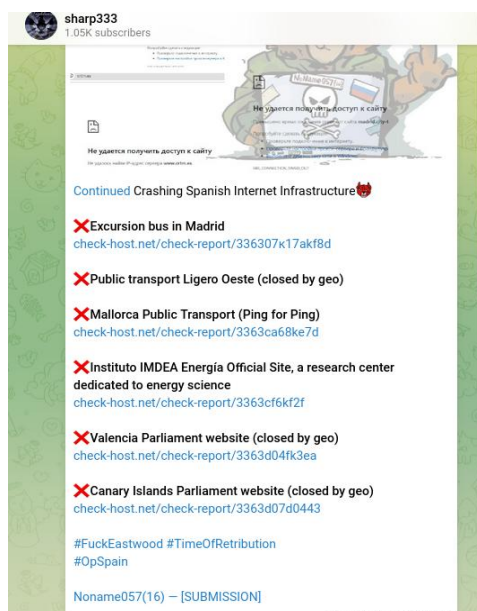


Fig. 20. Vía Telegram. sharp333. Ataques al transporte español 29/11/2025

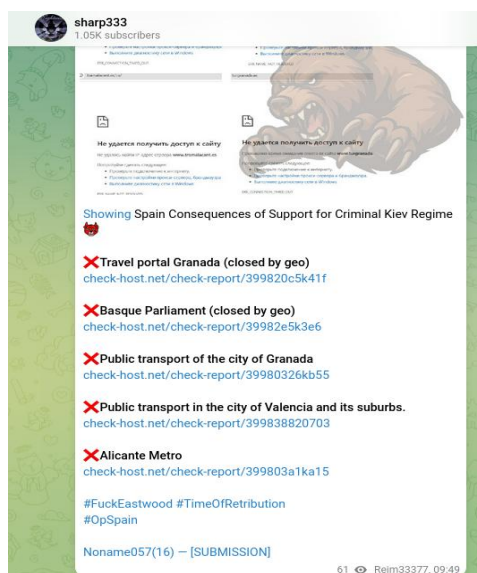


Fig. 21. Vía Telegram. sharp333. Ataques al transporte español 16/02/2026



Fig. 22. Vía Telegram. sharp333. Ataques al transporte español 20/02/2026

13.3 Anexo III

Análisis estadístico Telegram

[Análisis estadístico de los canales de Telegram](#)

13.4 Anexo IV

Relación entre grupos que forman parte de ZPENTEST ALLIANCE.

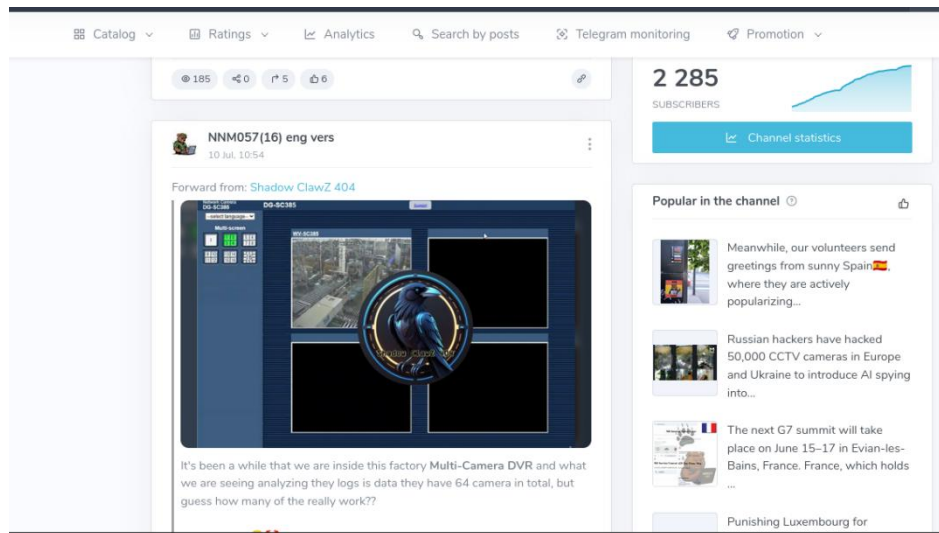


Fig. 23. Vía TGStat. NNM057(16). Relación con Shadow ClawZ 404



Fig. 24. Vía TGStat. inteid. Relación con RubinGroup

Si alguien pensaba que dejábamos de trabajar en el enemigo, ¡el enemigo estaba seriamente equivocado!

Incluso de vacaciones, seguimos trabajando duro, y a los pintores les gustan los pasteles calientes.

PD: perras, compramos todo!!!

No podemos poner una lástima en el canal.

¡Gloria a Rusia!

¡La victoria será nuestra!

¡El enemigo será derrotado!

#smeshariki

#PerunSwarogaga

#Nebeau

El Kremlin de Murchallo

#QuietSec

#inteid

#Z-Pentest

#noname-057(16)

Fig. 25. Vía TGStat. Svarog Peruno. Relación entre smeshariki, Svarog Peruno, QuietSec, inteid, Z-Pentest, noname057(16)

13.5 Anexo V

Relación de APK con ZPENTEST ALLIANCE.

😊 **AvangardSec** Oficialmente comienza la operación **A la sangre transmitida. Junto con Pol4rity.**

También se unió a la operación **INTEID**

SOC: Busca nuestras marcas ;)
 L DEAFICKV3
 L AVANWARE - "Avangard Ultimate"
 L etc..

Bloodborne - Operación cibernética organizada **Ojo de Sauron** Dirigido a la infraestructura de Alemania, España.

España ha bloqueado previamente las cuentas de Rosneft de 1.2 mil millones.

Dos veces violó el tratado de no proliferación. Despliegue de bombas nucleares B61

Alemania cometió directa y abiertamente un ataque contra el Ministerio de Defensa de la Federación de Rusia.
 Datos trifurados de los grupos VGTRK y entregas de tanques LEOPARD 2A6

Respondemos simétricamente. Los próximos ataques no se encuentran en instalaciones militares, sino en sistemas para los que ellos mismos hacen sonar la alarma.

L red eléctrica
 L Finanzas
 L Logística
 L empresas científicas

🇷🇺 A/P/K - @AvangardsSec

Fig. 26. Vía TGStat. AvangardSec. Relación entre APK e inteid



Fig. 27. Vía TGStat. pol4rity. Relación entre APK con QuietSec

13.6 Anexo VI

Índice de confianza de las fuentes

La rigurosidad de un análisis de ciberinteligencia depende no solo de los datos que se manejan, sino de evaluar la fiabilidad de las fuentes de las que proceden. Por lo tanto, para llevar a cabo este análisis, se ha decidido, en primer lugar, diferenciar entre fuentes primarias, informes oficiales de instituciones y organismos con competencia directa, y secundarias, medios de comunicación verificados y los análisis de terceros; y, en segundo lugar, aplicar el Admiralty Code de la OTAN, también conocido como NATO System, que codifica cada fuente con una letra para la fiabilidad de la fuente, de la A (totalmente fiable) a la F (no evaluable), y con un número para la credibilidad de la información, del 1 (confirmada) al 6 (no evaluable).

El siguiente hipervínculo da acceso a un Excel en el que se representa el índice comentado: [INDICE DE CONFIANZA](#)

El Excel es otro motivo que respalda la asimetría de evidencia anticipada en el apartado de limitaciones, según el tipo de actor que se analice.

13.7 Anexo VII

Glosario

ACARS	Sistema de comunicación y direccionamiento de aeronaves para el intercambio de mensajes operativos entre la aeronave y tierra.
Actor de amenaza (Threat Actor)	Individuo o grupo responsable de un evento o incidente de seguridad, clasificado por su motivación y capacidad en estatal, criminal, hacktivista o insider.
ADS-B	Vigilancia dependiente automática por radiodifusión, mediante la cual las aeronaves difunden su posición derivada del GNSS para el control del tráfico aéreo.
Air gap (aislamiento físico)	Desconexión física de un sistema crítico respecto de las redes externas; paradigma tradicional de los entornos OT, hoy erosionado por la convergencia IT/OT.
AIS (Automatic Identification System)	Sistema de identificación automática que intercambia datos de posición, rumbo y velocidad entre buques para evitar colisiones.
API	Interfaz de programación de aplicaciones utilizada para interactuar con servicios externos (mencionada en VirusTotal, MISP, Shodan, Ransomware.live y Telegram).
APT (Amenaza Persistente Avanzada)	Actor, generalmente patrocinado por un Estado, caracterizado por su sofisticación, su persistencia en el objetivo y su orientación al espionaje o al sabotaje a largo plazo.
Ataque a la cadena de suministro	Compromiso de un proveedor o componente de confianza para alcanzar, en cascada, a sus clientes.
Ataque de abrevadero (watering hole)	Compromiso de un sitio web legítimo frecuentado por la víctima con el fin de infectar a quienes lo visitan.
Atribución	Proceso de determinar la autoría de un ciberataque a partir de la evidencia técnica, operativa y contextual; es inherentemente compleja y a menudo provisional.
AWK / JQ	Herramientas del sistema utilizadas para la extracción, procesamiento de datos estructurados (ETL) y normalización de formato JSON.
Beaconing	Comunicación periódica y discreta de un sistema comprometido con su infraestructura de mando y control, a menudo con frecuencia irregular para evadir la detección.
BEC (Business Email Compromise)	Fraude basado en el compromiso o la suplantación del correo corporativo para inducir transferencias o desviar información.
Bot	Programa automatizado en Telegram encargado de recibir y proporcionar al analista las alertas enriquecidas.

Botnet	Red de dispositivos comprometidos y controlados de forma remota por un atacante, empleada habitualmente para ejecutar ataques DDoS a gran escala.
Bulletproof hosting	Servicios de alojamiento que toleran deliberadamente la actividad ilícita y resisten las solicitudes de retirada, sirviendo de base a la infraestructura criminal.
C2 (Command and Control)	Infraestructura que un atacante utiliza para comunicarse con los sistemas comprometidos, enviar órdenes y exfiltrar datos.
Caché MD5	Sistema local de <i>hashing</i> utilizado por el middleware para registrar IDs previamente procesados y evitar la duplicación de eventos.
Caza de amenazas (threat hunting)	Búsqueda proactiva e hipotética de adversarios ya presentes en la red que han logrado evadir las defensas automáticas.
Ciclo de vida de la inteligencia	Proceso iterativo de producción de inteligencia compuesto por las fases de dirección, recolección, procesamiento, análisis, difusión y retroalimentación.
Credential stuffing	Uso automatizado de credenciales robadas en un servicio para intentar acceder a otros, aprovechando la reutilización de contraseñas.
Crime-as-a-Service (CaaS)	Modelo del cibercrimen organizado en el que distintas capacidades delictivas —accesos, malware, phishing o DDoS— se ofrecen como servicios de pago.
Cron / Cronjobs	Programador de tareas del sistema operativo utilizado para ejecutar periódicamente los scripts de recolección en minutos escalonados.
crt.sh	Registro público de certificados empleado para monitorizar subdominios asociados a las empresas.
CSIRT / CERT	Equipos de respuesta a incidentes de seguridad informática; en España, INCIBE-CERT y CCN-CERT constituyen las referencias nacionales.
CTI (Inteligencia de Ciberamenazas)	Enfoque proactivo de ciberseguridad orientado a anticiparse a los incidentes mediante la recolección y estudio de amenazas.
CVE	Vulnerabilidades y exposiciones comunes asociadas a los puertos críticos descubiertos a través de Shodan.
CVSS	Sistema de puntuación que mide la gravedad de una vulnerabilidad en una escala de 0 a 10.
Cyber Kill Chain	Modelo que describe las fases secuenciales de una intrusión, desde el reconocimiento hasta la acción sobre los objetivos.
Dark Web	Parte de internet no indexada, monitorizada para buscar dominios expuestos y foros de actores de amenazas.
Data Leak Site (DLS)	Sitio web, habitualmente en la red Tor, donde los grupos de ransomware publican los datos de las víctimas que no pagan, como mecanismo de presión.

DDoS (Denegación de Servicio Distribuida)	Ataque que satura un servicio con tráfico procedente de múltiples fuentes para dejarlo inoperativo; es la técnica predilecta del hacktivismo.
DDoSia	Herramienta y plataforma de denegación de servicio distribuida del grupo NoName057(16), basada en un modelo de «voluntariado gamificado» retribuido en criptomonedas.
Deepfake	Contenido sintético de audio, vídeo o imagen generado con inteligencia artificial para suplantar identidades en fraudes o campañas de desinformación.
Defacement	Modificación no autorizada del contenido visible de un sitio web, empleada con frecuencia por el hacktivismo como acción de propaganda.
Defensa en profundidad	Estrategia que superpone múltiples capas de control de seguridad, de modo que el fallo de una de ellas no comprometa el conjunto del sistema.
Diamond Model	Modelo analítico que relaciona los cuatro vértices de un incidente: adversario, capacidad, infraestructura y víctima.
Doble extorsión	Táctica que combina el cifrado de los sistemas con la amenaza de publicar los datos robados; la triple extorsión añade DDoS o avisos a clientes y socios.
DORA	Reglamento europeo de resiliencia operativa digital, aplicable al sector financiero y a sus proveedores de servicios TIC desde enero de 2025.
Dorks	Técnicas de búsqueda avanzada utilizadas en motores como DuckDuckGo para localizar información en repositorios públicos.
Doxing	Recopilación y publicación de información personal o sensible de un objetivo con fines de presión, represalia o coacción.
EASM (External Attack Surface Management)	Gestión de la superficie de ataque externa, esto es, la identificación y la monitorización continua de los activos expuestos a Internet de una organización.
ECDIS	Sistema electrónico de visualización de cartas náuticas integrado con datos de navegación, que da soporte a la planificación de rutas.
EDR (Endpoint Detection and Response)	Solución de seguridad que monitoriza los dispositivos finales para detectar y responder a comportamientos maliciosos.
ELK (Stack)	Ecosistema de herramientas (Elasticsearch, Logstash, Kibana) mencionado como alternativa más compleja frente al uso de Wazuh.
ERTMS / ETCS	Sistema europeo de gestión del tráfico ferroviario y su componente de señalización y control de tren, base de la interoperabilidad ferroviaria.
Escalada de privilegios	Obtención de un nivel de permisos superior al inicial con el fin de acceder a recursos restringidos del sistema.

ETL (Extracción, transformación y carga)	Proceso utilizado en el script integrador para procesar y normalizar los datos de la alerta.
Exfiltración de datos	Sustracción no autorizada de información desde la red de la víctima hacia infraestructura controlada por el atacante.
Fatiga de Alertas (<i>Alert Fatigue</i>)	Fenómeno operativo que reduce la eficiencia del SOC debido a la saturación de volúmenes inabarcables de ruido y datos innecesarios en el SIEM.
Feed de inteligencia	Flujo de datos, como IOCs, avisos o vulnerabilidades, suministrado de forma continua por una fuente para su consumo automatizado.
FQDN	Nombre de dominio completamente calificado, analizado en los certificados mediante librerías para dividir y evaluar el subdominio.
GNSS	Sistema global de navegación por satélite, como GPS, Galileo o GLONASS, base de la navegación y la sincronización de múltiples sistemas de transporte.
GPS jamming	Interferencia que bloquea la recepción de la señal de navegación por satélite, provocando su pérdida.
GPS spoofing	Falsificación de la señal de los sistemas de navegación por satélite para engañar la posición de un buque, una aeronave o un vehículo.
Hacktivismo	Uso de técnicas de ataque, típicamente DDoS o defacement, con una motivación política o ideológica y no económica, buscando visibilidad e impacto reputacional.
Hardcodeado	Práctica de incluir términos fijos directamente en el código fuente, evitada en este proyecto mediante el uso de listados dinámicos.
HMI (interfaz hombre-máquina)	Panel mediante el cual los operadores supervisan y controlan los procesos industriales de un sistema ICS/SCADA.
Honeypot	Sistema señuelo diseñado para atraer y registrar la actividad de los atacantes con fines de detección y estudio.
HTTPS / TLS	Protocolos que garantizan que las comunicaciones viajen cifradas en tránsito (mencionados en la integración segura de Telegram)
ICS / SCADA	Sistemas de control industrial y de supervisión y adquisición de datos que gobiernan procesos físicos; en transporte, la gestión portuaria, ferroviaria o de suministro.
IncidentBuddy	Plataforma de inteligencia utilizada para perfilar estratégicamente a los actores de amenazas.
Infostealer	Malware especializado en el robo masivo de credenciales, cookies y datos del navegador, principal proveedor de accesos del mercado clandestino.
Initial Access Broker (IAB)	Actor criminal especializado en obtener y vender accesos iniciales a redes corporativas comprometidas, que alimenta a los grupos de ransomware.

Insider (amenaza interna)	Riesgo originado por personas con acceso legítimo a los sistemas, como empleados o contratistas, ya sea de forma malintencionada o por negligencia.
Inyección de prompt indirecta (IPI)	Ataque emergente contra los asistentes de inteligencia artificial que oculta instrucciones maliciosas en contenido aparentemente legítimo para exfiltrar datos o alterar su comportamiento.
IoC (Indicadores de Compromiso)	Evidencias o datos recolectados en internet para identificar de forma temprana ciberataques en curso o materializados.
IT/OT (convergencia)	Integración de las tecnologías de la información con las tecnologías de operación que controlan procesos físicos, lo que amplía la superficie de ataque.
JSON	Formato ligero de datos utilizado para ingestar los eventos directamente en el SIEM y estructurar el envío hacia Telegram.
Living-off-the-Land (LotL)	Técnica de evasión que abusa de herramientas y binarios legítimos del propio sistema, lo que reduce la huella y dificulta la detección.
Loader / dropper	Componente de malware cuya función es descargar y ejecutar la carga maliciosa principal en una fase posterior del ataque.
Logrotate	Herramienta nativa del sistema operativo en la que se delega el mantenimiento y retención de logs para optimizar espacio en disco.
Malware-as-a-Service (MaaS)	Comercialización de malware, típicamente infostealers, mediante suscripción, que reduce la barrera técnica de entrada al delito.
Malware sin fichero (fileless)	Código malicioso que opera en memoria o mediante herramientas legítimas, sin escribir un ejecutable en disco, lo que dificulta su detección.
MFA (Autenticación Multifactor)	Mecanismo que exige más de un factor de verificación para acceder a un sistema, dificultando el uso de credenciales robadas.
MISP (Malware Information Sharing Platform)	Plataforma CTI de código abierto utilizada como repositorio central para compartir, almacenar y estructurar la inteligencia.
MITRE ATT&CK	Framework o marco de trabajo utilizado para perfilar y extraer tácticas y técnicas (TTPs) de los actores de amenazas.
Modelo Purdue	Arquitectura de referencia para la segmentación por niveles de las redes industriales, base del diseño seguro de los entornos ICS/OT.
Movimiento lateral	Desplazamiento del atacante entre sistemas dentro de la red comprometida tras el acceso inicial, en busca de activos de mayor valor.
NIS2	Directiva europea de seguridad de las redes y sistemas de información que refuerza las obligaciones de ciberseguridad de los operadores esenciales, incluido el transporte.
OAuth2	Sistema de autenticación complejo no requerido gracias a la simplicidad de conexión directa de los Webhooks de Telegram.

OpenCTI	Plataforma CTI basada en microservicios, descartada en el diseño por requerir mayores recursos de hardware que MISP.
Operación de bandera falsa (false flag)	Técnica por la que un atacante imita los TTPs o la infraestructura de otro actor para inducir una atribución errónea.
OPSEC (Seguridad Operacional)	Uso de prácticas y restricciones (como cargar variables desde .secrets.env) para proteger datos sensibles de la propia infraestructura.
OSINT (Inteligencia de fuentes abiertas)	Inteligencia obtenida de fuentes públicas accesibles, como canales RSS y flujos de noticias.
Persistencia	Conjunto de técnicas que permiten al atacante mantener el acceso a un sistema tras reinicios o cambios de credenciales.
Phishing / Spear phishing	Ingeniería social que suplanta a una entidad de confianza para robar credenciales o distribuir malware; el spear-phishing es su variante dirigida a objetivos concretos.
PLC (controlador lógico programable)	Dispositivo industrial que automatiza procesos físicos en entornos OT; objetivo de grupos como CyberAv3ngers.
Port Community System (PCS)	Plataforma digital que integra a todos los actores de un puerto, como la autoridad, las terminales, las aduanas y los transitarios, para el intercambio de información logística.
Proxy SOCKS5	Herramienta local utilizada para enrutar el tráfico del scraper que opera sobre la Dark Web.
PTC / CTC	Positive Train Control y Control de Tráfico Centralizado, sistemas de gestión y seguridad del tráfico ferroviario.
PyMISP	Librería que permite a los scripts en Python interactuar, inyectar y deduplicar eventos de forma eficiente en MISP.
Pyramid of Pain	Modelo que jerarquiza los indicadores según el dolor que su detección causa al atacante, desde los hashes, triviales de cambiar, hasta las TTPs, muy costosas de modificar.
RaaS (Ransomware-as-a-Service)	Modelo de negocio criminal en el que los desarrolladores del ransomware alquilan su infraestructura a afiliados a cambio de una comisión, lo que industrializa y escala los ataques.
Ransomware	Software malicioso que cifra los datos o sistemas de la víctima para exigir un rescate; en su evolución actual prima la extorsión basada en la exfiltración de datos sobre el propio cifrado.
RAT (troyano de acceso remoto)	Malware que otorga al atacante control remoto e interactivo sobre el sistema comprometido.
RCE (ejecución remota de código)	Explotación que permite a un atacante ejecutar código arbitrario en un sistema a través de la red, sin acceso físico.
RegEx (Expresiones Regulares)	Patrones de búsqueda avanzados utilizados en los scripts para filtrar inteligencia y extraer el dato.

Reglas Sigma	Formato genérico y abierto de reglas de detección para logs y eventos, equivalente a YARA en el ámbito de los SIEM.
Reglas YARA	Patrón de reglas utilizado para identificar y clasificar muestras de malware a partir de características textuales o binarias.
Sandbox (entorno aislado)	Entorno controlado y aislado donde se ejecuta código sospechoso para analizar su comportamiento sin riesgo para la red de producción.
Scrapers	Módulos desarrollados en Python encargados de la recolección activa de datos, extracción y etiquetado desde diversas fuentes.
SIEM (Security Information and Event Management)	Plataforma centrada en el monitoreo, correlación y análisis en tiempo real de eventos de seguridad (ej. Wazuh).
SOC (Centro de Operaciones de Seguridad)	Equipo o instalación dedicada a la ciberdefensa, tradicionalmente de naturaleza reactiva.
STIX	Lenguaje y formato estandarizado para representar de forma estructurada información de ciberamenazas.
Suplantación de marca (brand impersonation)	Creación de dominios, certificados o sitios que imitan a una organización legítima para el fraude o el phishing; detectable mediante Certificate Transparency.
Tagging (Etiquetado)	Proceso de clasificar eventos en MISP con marcas granulares (ej. Sector:Logística) imprescindibles para el filtrado posterior.
TAXII	Protocolo de transporte que permite el intercambio automatizado de inteligencia, típicamente codificada en STIX, entre plataformas.
Taxonomía (en MISP)	Conjunto de etiquetas normalizadas que permiten clasificar y filtrar eventos e indicadores de forma coherente, por sector, país, tipo de amenaza o TLP.
Tiempo de permanencia (dwell time)	Periodo que transcurre desde la intrusión inicial hasta su detección; cuanto mayor es, mayor resulta el daño potencial.
TIP (Threat Intelligence Platform)	Plataforma para agregar, normalizar, correlacionar y compartir inteligencia de amenazas; en este trabajo se emplea MISP.
tldextract	Librería de Python empleada para dividir las partes que componen una URL (FQDN) y analizar específicamente los subdominios.
TLP (Traffic Light Protocol)	Esquema de clasificación que regula la difusión de la información compartida mediante un código de colores: RED, AMBER, GREEN y CLEAR.
Tor / Onion	Red de anonimato donde operan foros clandestinos rastreados por los scrapers.
TTPs (Tácticas, Técnicas y Procedimientos)	Comportamientos, métodos y estrategias estudiadas de los actores de amenazas.

VirusTotal	Plataforma utilizada para validar IoCs detectados mediante consultas pasivas (GET).
WAF (Escudos anti-bot)	Sistemas de protección web que generan bloqueos (errores 403 y 429) gestionados durante el raspado de información.
Wazuh	Plataforma de seguridad unificada que actúa como SIEM nativo para el análisis de los eventos
Webhook	Petición HTTP directa (POST) utilizada para enviar las alertas procesadas hacia la plataforma de Telegram de forma ágil.
Wiper	Malware destructivo cuyo fin no es el rescate, sino la inutilización irreversible de datos o sistemas; característico de la guerra híbrida, como el empleado por Sandworm.
XDR	Evolución del SIEM y del EDR que integra la detección y la respuesta extendida a través de múltiples capas, como endpoint, red y nube.
Zero-day	Vulnerabilidad desconocida para el fabricante y sin parche disponible, especialmente peligrosa por la ausencia de defensa específica.
Zero Trust (confianza cero)	Modelo de seguridad que no concede confianza implícita a ningún usuario o dispositivo y verifica de forma continua cada acceso.
